

소프트웨어 개발보안

안전한 소프트웨어 개발을 위한
가이드라인

2016.05



목차

Part1. 최근 보안동향

Part2. 소프트웨어 개발보안

Part3. AI 개발 보안

최근 보안 동향

Secure Coding Education



Building Robust and Resilient Software

최근 보안 동향

개발자의 미래

5년 뒤 '이능력' 가진 사람이 희귀해질 겁니다

기술은 AI,
소통은 인간

정답이 있는 일
협업해야 하는 일

정답이 없는 일
협업해야 하는 일

인간이 문제 제기
AI가 기술을 담당

AI가 대체

정답이 있는 일
혼자 할 수 있는 일

정답이 없는 일
혼자 할 수 있는 일

인간과 AI의 협업

이 문제에 대한 문제의식을 던져주는 거는 사람이 해 주고

AI 시대 가장 빨리 도태될 회사의 특징 '가치'

2023년

프로그래밍을
잘해야 살아남는다

2024년

AI 도구를
잘 써야 살아남는다

2025년

바이트 코딩을
잘 해야 살아남는다

2026년

에이전트 AI를
많이 써야 살아남는다

그러니까 정말 놀랍게도 인공지능 시대의 생존 전략이

4



최근 보안 동향

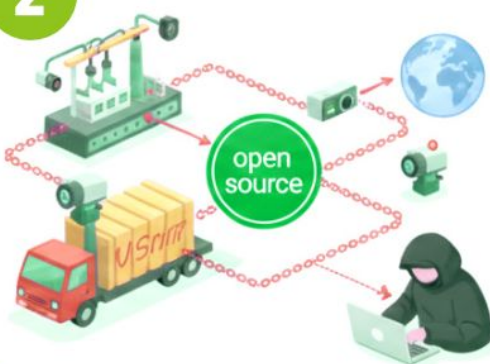
2025년 사이버 위협

1



**국민 생활과 밀접한
다수 침해사고 사례**

2



**오픈소스 및 IoT 생태계를
악용한 공급망 사고사례**

3



**다수 고객망 운영기업 대상,
랜섬웨어 사고사례**

최근 보안 동향

2025년 사이버 위협

1 일상을 위협하는 생활 밀접 인프라에 대한 침해사고

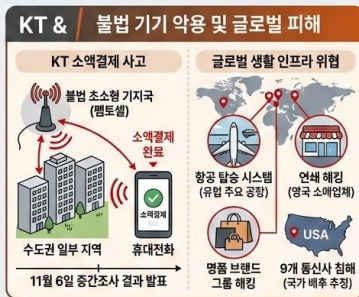
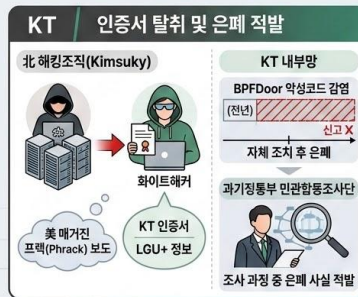
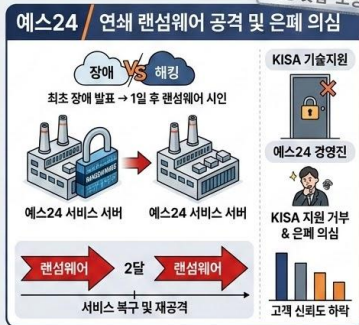
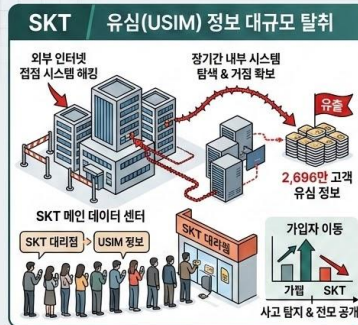
- 생활 밀접 분야에서 연속적인 침해사고 및 개인정보 유출 발생
- 침해사고 발생을 축소·은폐하려는 것으로 의심되는 사례 등 국민불안 심화

2025년은 2,383건으로 역대 가장 많은 사이버 침해사고('25.11월 기준 2,167건, '24년 1,887건)가 발생했다. 침해사고에 따른 개인정보 유출 규모도 역대급이라고 할 수 있으며, 침해사고 발생 분야도 통신, 유통, 금융 등 국민 생활 밀접 분야에서 발생하면서 많은 국민을 불안하게 했다.

주요 침해사고 사례

- 'SKT 해킹' 3년 전부터 시작...유심 정보 2,700만건 털렸다(4월)
- '랜섬웨어 해킹' 에스24, 두 달 만에 또 먹통(6월, 8월)
- SK텔레콤 이어 KT·롯데카드까지...'해킹 포비아' 대한민국(8월)

통신·커머스·온라인 서비스의 붕괴



최근 보안 동향

2025년 사이버 위협

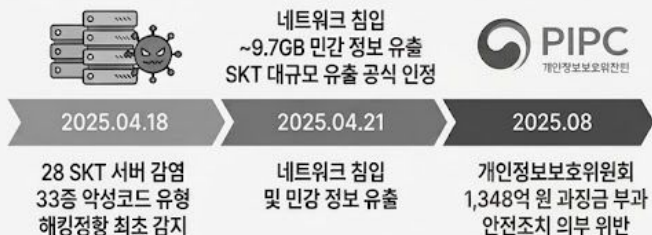
피해 기업 및 사고	피해 규모	공격 벡터	근본 취약점 (Root Cause)
SKT	유심(USIM) 정보 2,696만 건 유출	외부 접점 시스템 침투 및 거점 확보	⚠ 통신 기반 신원체계의 구조적 허점 방치
쿠팡	회원 정보 3,370만 건 유출	내부망 접근 우회	⚠ 퇴사자 액세스 토큰 서명키 미회수 (최악의 내부 권한 통제 실패)
KT	2만 2천여 명 피해, 소액결제 사기	차량 탑재 불법 초소형 기지국(팸토셀) 악용	⚠ SMS 인증망 및 물리적 접근 기반의 구조적 노출
에스24	2개월 간격 연쇄 서비스 마비	랜섬웨어 감염	⚠ 기술지원 종료(EOS) 윈도우 서버 방치 및 초기 대응 축소 시도

최근 보안 동향

2025년 사이버 위협

SKT (SK텔레콤) 2025 대규모 데이터 유출 사건

1. 사건의 전말



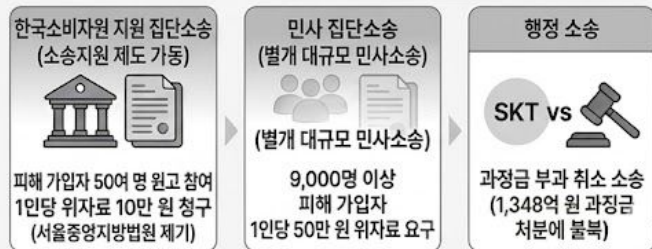
2. 피해 규모



3. 분쟁 조정과 SKT의 거부

구분	조정 기관	조정안 내용	SKT 대응 결과
1차 조정 2025.11	개인정보보호 분쟁조정위	신청 피해자 약 4,000명에게 1인당 현금 30만 원 지급 권고	최종 거부 (전체 고객 확대 시 최대 7조 원 부담 우려)
2차 조정 2025.12	한국소비자원 분쟁조정위	통신 요금 할인 + 멤버십 포인트 (총 10만 원 상당)	최종 거부 (2026.01 불수용 의용 의사 밝힘, 전체 적용 시 2.3조 원 규모)
결과	진찰 조정 (두둑 이 ~7조 원 최초부던	Final Rejection in 2026.01 (창개 적용 시 2.3조 원 규모)	

4. 현재 진행 상황



SKT의 입장: 자체 선제적 보상 노력 미반영 주장 (유심칩 무상 교체, 위약금 면제, 요금 할인)

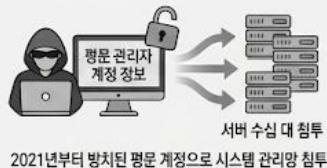
최근 보안 동향

2025년 사이버 위협

SKT 데이터 유출 사고: 원인과 시사점

1. 발생 원인

1 평문 계정 방치



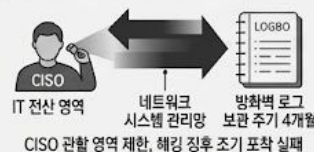
2 유심 인증키(Ki) 미비



3 공급망 보안 검증 실패



4 보안 사각지대 존재 및 모니터링 부실



4 보안 사각지대 존재 및 모니터링 부실



5 능력 대응 및 신고 의무 위반



2. 시사하는 점

1 제로 트러스트(Zero Trust) 체계 도입 필수



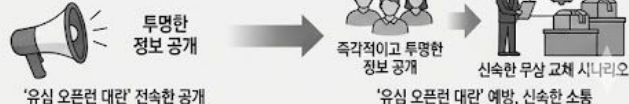
2 통신 인증 정보의 법적 보호 강화



3 전사적 보안 통합 거버넌스 구축



4 투명한 위기 대응 프로세스 확립



최근 보안 동향

2025년 사이버 위협

2 오픈소스 및 저가형 IoT 생태계를 악용한 공급망 공격

- 오픈소스 저장소를 통해 악성코드를 유포하려는 시도 발생
- 백도어 탑재, 보안 설정 미흡 등 보안에 취약한 형태로 유통되는 저가형 단말기 악용

오픈소스 생태계를 통한 AI 공급망 공격도 본격화되고 있다. 美 보안기업 Sonatype에 따르면 2025년 2분기 신규 악성 패키지가 전년동기 대비 188% 급증한 16,279개가 등록되었으며, Hugging Face, GitHub, NPM 등 개발자들이 신뢰하는 오픈소스 플랫폼이 주요 공격 경로로 악용되고 있다. 특히 AI 모델 저장소와 전통적 소프트웨어 패키지 관리 시스템이 결합하면서 공격표면이 크게 확대되고 있다.

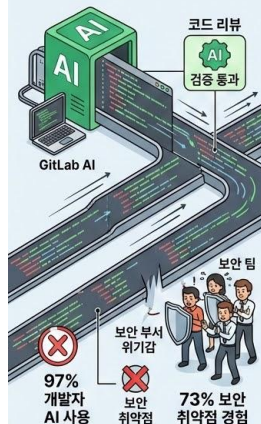
주요 사고 사례 및 동향

- FBI, BADBOX 2.0 악성코드로 100만 대 이상 감염 경고(6월)
- npm, PyPI 공급망 악성코드 공격 피해 심각...오픈소스 생태계 위협 급증(9월)
- 북한 해커, npm 악성 패키지 197개 추가..개발자 타깃 대규모 악성코드 공격 확인(12월)

출처: kisa 25년 사이버 위협 동향 및 26년 전망

속도 중심의 AI 개발로 인한 취약점 증폭

위기가 가져짐

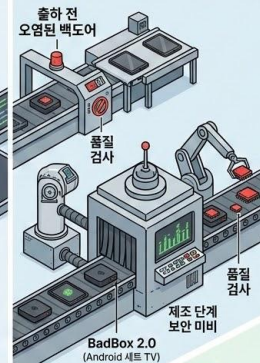


SBOM 활용 및 기기 지속 관리

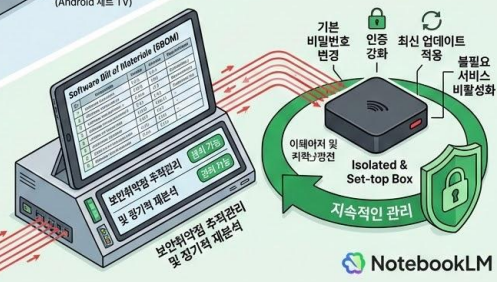
중국에 대장을 금어자 기속하여, 보안적으로 판상하 초기 제품 보안 취약점 개적저작을 관학

BadBox 2.0 및 초기 오염 장비 확산

중국원이산 제조 재산의 스마트 소터임 미비 출산



SBOM 활용 및 기기 지속 관리



최근 보안 동향

2025년 사이버 위협: BadBox2.0



최근 보안 동향

2025년 사이버 위협: BadBox2.0

홈 > 글로벌 > ICT

태블릿등 저가 모바일 장치 감염 '배드박스 2.0'...FBI, "안드로이드 기기 조심" 경고

A 조만수 기자 | ② 입력 2025.06.01 15:31 | 배정글 0





[아티티(덜리)] 지난 3월 백드박스(BadBox)로 알려진 봇넷이 셋톱박스(STB), 프록시, 태블릿 등 100만 대 이상의 안드로이드 운영체제 탑재 기기를 오염시켰고 있다는 보고서가 나왔다. 그런데 최근 더 진보된 '백드박스 2.0'이 전 세계 22개국에서 최소 수백만 대의 안드로이드 기기에 감염되고 있다는 결과가 나왔다.

구글은 사용자 보호를 위해 조치를 취하는 동시에, 공격자에 대한 법적 대응도 시작했다고 공식 발표했다. FBI(미국연방수사국)는 백드락스 2.0에 감염된 사용자에게 기기를 즉시 인터넷에서 분리하라고 강력히 권고했다. 이 소식은 CNN, 로이터 등 다수의 매체를 통해 전해졌다.

간과하여 따르면 FBI의 사이버 보안 경고는 "060525-PSA"는 명확한 메시지를 전달하고 있었다. 현재 진행 중인 공격은 STB, 스마트TV 등 스트리밍 장치, 디지털 포토 프레임, 스마트 차량용 컴퓨터 인스턴트 시스템, 기타 가정용 스마트 디바이스를 표적으로 한다. 또한, 안드로이드에 기반 탑재된 보안이 가능한 구글 플레이 스토어에 있는 응용 프로그램을 비롯해도 포함된다. 이들 기기는 대부분 중국산이라는 특징이 있다. 특히 안드로이드의 인증을 받지 않은 제품일 수도 있다.

- 아이폰/애플워치, 스마트워치 362만여 - 전년 대비 130%
- [미국] 해커 한국 전직 간첩 - 첫날 100여명, 2차 10여명
- '카카오톡' 해킹 48시간 동안 - 4만 4천 명, 10만 명
- LGU+, 삼성카드 해킹 48시간 동안 - 4만 4천 명, 10만 명

프로토콜에 따르면 FB는 "사용자가 제품을 구매하기 전부터 작성 소프트웨어가 기기기에 설치되어 있으며, 공격자가 가정 내 네트워크, 나아가 외부 네트워크로도 접근할 수 있다"고 경고하고 있다. 또 한, 초기 설치 시 비공식 마켓플레이스를 통해 요구되는 '소프트웨어 업데이트'에 의해 작성 백도어가 추가될 가능성이 있다고 한다.

보안 기업 포인트와일드의 위험 인텔리전스 팀 LAT61은 버드박스 2.0 감염 과정을 리버스 엔지니어링해 새로운 침해 지표(ioc)를 발견하고, 이를 전 세계 컴퓨터 긴급 대응팀(CERT) 및 법 집행기관에 공유했다.

LAT61 칩은 '이 안드로이드 기반 액싱코드 텔레에는 지가령 IoT 장치, 스마트 TV, TV 박스, 태블릿 등의 텔레에 (공장 출고 전부터) 미리 설치되어 있다. 사용자도 모르는 사이에 클릭 사기, 인증정보 공격, 은밀한 (2)이전 및 제3) 통신에 사용되는 '자택 프로시노드'로 바뀌고 있다.'고 말했다.

구글은 지난 7월 17일 "백드믹스 2.0" 운영자들을 뉴욕 연방지방법원에 제소했다"고 공식 발표했다. 또한 "구글 플레이 프로젝트를 업데이트해 백드믹스 관련 앱을 자동으로 차단하도록 조치했다"고 밝혔다.

패드박스 2.0의 위험을 최초로 공개하고 차단한 것은 보안 기업 휴먼시큐리티의 '사토리 위험 분석 팀'이었다. 휴먼 "여러 위험 행위자가 패드박스 2.0에 관여했으며, 이들은 북한의 기반 인프라 구축, 검열 기기를 수입하려는 사기, 모뎀(관과 사기, 클릭 사기, 폭풍시 제련에 등에 관련되어 있었다"고 분석했다. 이 북핵은 전세계 222개국 및 지역에 걸쳐 운영되고 있다고 한다.

휴먼시큐리티는 “우리가 발견한 배드박스 2.0 뜻에 대해 구입이 신속히 대응한 것은 다행이다. 배드박스 2.0은 사용자 기기를 발견하고 균형을 빼앗고 소비자 모르게 착취하는 고도화된 사기 행위 를 막는 큰 진전이다”라고 평가했다. 나아가 배드박스 차기 버전이 등장할 가능성이 높다는 경고도 내렸다.



기획특집

최신뉴스



권고안에 따르면 FBI의 사이버 보안 경고문 'I-060525-PSA'는 명확한 메시지를 전달하고 있다. 현재 진행 중인 공격은 STB, 스마트TV 등 스트리밍 장치, 디지털 포토프레임, 서드파티 차량용 인포테인먼트 시스템, 기타 가정용 스마트 디바이스를 표적으로 한다. 또한, 안드로이드에 기본 탑재된 보안 기능인 '구글 플레이 프로텍트'의 인증을 받지 않은 태블릿도 포함된다. 이들 기기는 대부분 중국산이라는 특징이 있다. 특히 인증되지 않은 저가형 제품이 많다.

포브스 보도에 따르면 FBI는 “사용자가 제품을 구매하기 전부터 악성 소프트웨어가 기기에 심어져 있으며, 공격자가 가정 내 네트워크, 나아가 외부 네트워크에도 접근할 수 있다”고 경고하고 있다. 또한, 초기 설치 시 비공식 마켓플레이스를 통해 요구되는 ‘소프트웨어 업데이트’에 의해 악성 백도어가 추가될 가능성도 있다고 한다.

보안 기업 포인트와일드의 위협 인텔리전스 팀 LAT61은 배드박스 2.0 감염 과정을 리버스 엔지니어링해 새로운 침해 지표(loC)를 발견하고, 이를 전 세계 컴퓨터 긴급 대응팀(CERT) 및 법 집행기관에 공유했다.

출처: kisa 25년 사이버 위협 동향 및 26년 전망

최근 보안 동향

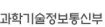
SBOM : SW 공급망 보안 가이드라인 (kisa)

2024. 05

요약본

SW 공급망 보안 가이드라인

SW 공급망 보안 국제동향 및 SBOM 활용사례



참고 국내외 SBOM 표준화 현황

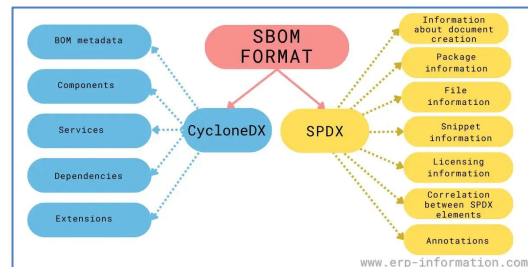
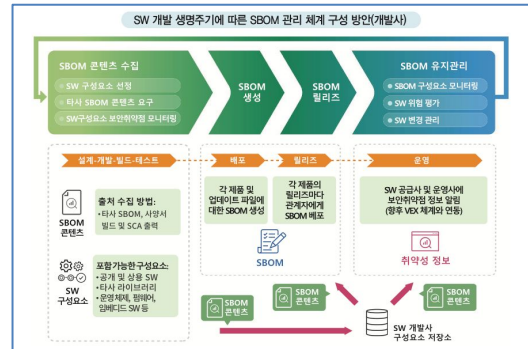
- SBOM 표준은 SBOM 공유 및 교환을 위한 자동화 요구사항으로 국내에서도 다양한 SBOM 포맷 개발과 표준화가 이루어지고 있음
- 특히, 미국 NTIA에서는 빠른 시장 적용을 위해 3가지(SPDx, CycloneDX, SWID)를 인용, 다만, SWID는 보안취약점 관리에 활용되지 않고 있음

구 분	SPDX	CycloneDX	SWID
목적	라이선스 관리	공급망 보안 관리	미국 정부의 SW 자산 및 보안 관리에 활용
개발 기관	리눅스재단	OWASP	미국 상무부 지원 프로젝트
주요 대상	공개 SW	공개 SW	상용 SW (주로 라이선스 추적·관리)
표준 (년도)	ISO/IEC 5962(‘21.8월)	-	ISO/IEC 19770-2(‘15)
파일 형식	.rdf, .xls, .spdx, .json, .yaml, .xml	.xml, .json	.xml

- 또한, 국내에서도 정부 및 민간 차원에서 각각 SBOM 표준 개발을 위해 노력 중

-(민간) SBOM 단체표준(TTA/KO-11.0182)은 SPDx v2.0을 참조하여 국내 활용을 위해 개선한 것으로 공개 SW 정보 교환 명세(Open Source Software Package Data Exchange Specification)에 중점을 두었고, 현재는 "공개 SW 공급망 관리를 위한 SW 목록 구성(SBOM) 속성 규격"(TTA/KO-11.0309, '22.12월)이 있음

-(정부) 국가정보원은 국가·공공기관에 도입되는 SW의 공급망 보안 관리 체계를 구축하기 위해 민간 협력으로 SBOM 기본항목을 개발, NIS-SBOM 기본항목은 ① 기본항목 간소화 ② 보안취약점 정보연동 ③ 사이버 위험관리 효율성 향상을 목표로 20개 기본항목을 정의하고 있음



최근 보안 동향

2025년 사이버 위협

3 랜섬웨어 공격 대상 확대와 기업-고객 연계 공격 강화

- 과거 민감분야(교육, 의료 등) 회피 경향과 달리 최근에는 분야 구분 없이 공격
- B2C 기업이나 단일 기업 침해를 통한 연쇄 패턴 공격 증가

사이버 공격의 주류가 된 랜섬웨어 그룹의 공격 대상이 연구·제조·에너지 분야를 넘어 교육·의료 등 공격 대상 분야를 계속 확대 해가고 있다. 그 수법 또한 AI 기술을 이용한 자동화나 연계형 공격으로 고도화 되어가고 있다.

주요 사고 사례 및 동향

- 美 신장치료 전문 기업 다비타, Interlock 랜섬웨어에 의한 침해 발생(4월)
- 美 병원 네트워크가 랜섬웨어 공격으로 전산 시스템 대거 중단(5월~6월)
- Qilin 랜섬웨어 그룹에 의한 다수의 국내 자산운용사 침해사고 발생(8월)
- 혈액공급기관 상대 초유의 랜섬웨어 공격.. "정보를 쥐고 있으니 협상하자"(11월)

[Case Study] 2025년 주요 의료·B2C 랜섬웨어 침해사고 매트릭스

	 [美 다비타 (DaVita)]	 [美 병원 네트워크]	 [국내 자산운용사]	 [혈액공급기관]
발생 시기	4월	5~6월	8월	11월
사건 개요	美 신장치료 전문 기업 대상 'Interlock' 랜섬웨어 침해	대규모 병원 네트워크 타겟 동시다발적 전산망 공격	'Qilin' 그룹, 국내 금융 IT 컨설팅 기업 침투를 통한 연쇄 공격	혈액공급기관 초유의 랜섬웨어 침투 및 시스템 장악
피해 규모	신장 투석 등 환자 생명과 직결된 핵심 치료 시스템 위협	전산 시스템 대거 중단으로 진료 차질 및 헬스케어 연쇄 피해 발생	다수의 자산운용사 고객 데이터 유출 및 운영 마비	국가 혈액 공급망 위협 및 환자 민감 정보(혈액형, 질병 등) 유출 위기
처리/대응 상황	FBI, CISA 등 주요 보안 기관이 Interlock 관련 공동 주의보 발령	인프라 긴급 복구 진행 및 의료기관 보안 강화 촉구	유출 데이터를 자산운용사별로 분리하여 '개별 협상' 시도 (신증 수법)	"정보를 쥐고 있으니 협상하자"는 이중 협박(Double Extortion) 진행 중

최근 보안 동향

2025년 사이버 위협

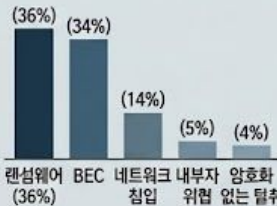
랜섬웨어의 정의 및 분류 [cite: 1]

정의: 시스템/데이터를 암호화하여
복호화/잠금 해제 대가로 금전 요구



랜섬웨어 피해 및 공격 현황 [cite: 1]

사이버 공격 유형 (발로알토 네트웍스):



악성코드 공격 유형 (포지티브 테크놀로지스):



누적 피해 금액 (2022년 3월 기준):



랜섬웨어의 다양한 악성 기능 [cite: 1]



가장 활발히 활동하는 랜섬웨어 [cite: 1]

1위: 콘티 (Conti)



기타 주요 그룹:

레빌 (REvil)
협박사 공격, 생산 중단
하이브 (Hive)
암호화폐 거래소 공격
포보스 (Phobos)
록빗 (Lockbit)
블름 새도 복사본 공격
블랙캣 (BlackCat)
블름 새도 복사본 삭제

복구 불능:



최근 보안 동향

2025년 사이버 위협

하반기 25년 사이버 위협 동향 및 26년 전망 Trend | 사이버 위협 동향

SKT 침해사고는 외부 인터넷 연결 접점이 있는 시스템에 대한 해킹을 통해 내부 서버에 침투 후 장기간에 걸친 내부 시스템 탐색과 거점 확보를 거쳐 SKT 전체 고객의 유심정보를 탈취해가는 과정에서 탐지되어 그 전모가 드러났다. 이 사고를 통해 SKT 약 2천6백만 고객의 유심정보가 유출된 것으로 확인되면서 불안한 가입자들이 유심교체를 위해 대리점에 긴 줄을 서는 안타까운 상황이 벌어졌고, 많은 SKT 고객이 다른 통신사로 이동하는 사태도 발생했다.

국내 대표 온라인 서점 예스24는 최초에는 시스템 장애로 인해 서비스 마비가 발생한 것으로 발생했으나, 하루 뒤가 돼서야 랜섬웨어로 인한 장애로 발표하면서 침해사고 사실을 축소하려고 했던 것은 아닌가 하는 의심을 사게 됐다. 또한, 예스24의 발표와는 달리 KISA의 기술지원에 동의하지 않은 사실이 드러나면서 사회적 비판의 대상이 되기도 했다. 서비스 복구 이후 2달 만에 또다시 랜섬웨어로 인한 서비스 마비가 발생했다. 최초 사고 이후 수립한 복구체계를 통해 당일 내 서비스를 복구했으나, 연이은 사이버 침해사고로 언론을 통해 '해킹 맛집'이라는 오명을 얻게 됐다.

1차 해킹 사태 (2025년 6월)

발생: 2025년 6월 9일 새벽 4시경
공격: 시스템 취약점을 이용한 랜섬웨어 공격(데이터 암호화 및 금전 요구).

원인: 기술 지원 종료된 구버전 윈도우 OS 사용으로 인한 보안 취약점.

피해 및 대처:

- 전체 서비스 5일 마비.
- 초기 '시스템 장애' 공지 후 36시간 만에 해킹 인정, 비판 야기.
- 백업 데이터 부재로 수십억 원 상당 비트코인 몸값 지불 후 암호화 해제.

2차 해킹 사태 (2025년 August)

- 발생: 2025년 8월 10일 새벽 4시 40분쯤.
- 상황: 1차 사태 두 달 만에 재차 랜섬웨어 공격 발생.
- 피해 및 대처: 준비된 백업 데이터 활용, 긴급 복구로 약 7시간 만에 서비스 정상화.

최근 보안 동향

3가지 역설



속도의 역설

Shift-Left와 자동화의 딜레마
개발 속도와 보안은 트레이드오프인가?



빠른 릴리스를 위한 자동화는
초기 취약점 탐지 기회를 증가시키지만,
동시에 더 많은 취약점을 조기에
유포할 위험도 가집니다.

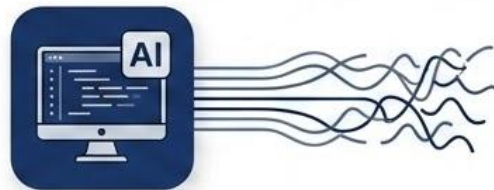


백업의 역설

랜섬웨어 시대의 이중 칼날
백업 데이터는 여전히 최후의 보루인가?



최신 랜섬웨어는 백업 데이터를 먼저
타깃으로 삼아 암호화 또는 유출시킵니다.
공격자에 대한 가시성 확보 없이는
백업 데이터 또한 인질이 됩니다.



AI 코딩의 역설

생산성 향상과 취약점 증폭
코딩 보조 도구는 완벽한가?

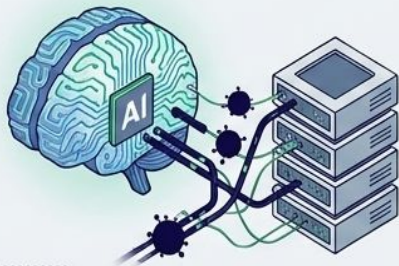


AI 도구는 개발 속도를 획기적으로
향상시키지만, 검증되지 않은 코드로 인해
잠재적인 보안 위협을 대량으로
생성할 수 있습니다.

최근 보안 동향

2026년 사이버 위협

1



AI 위협의 일상화

AI를 활용한 공격의 자동화·최적화 및 AI 서비스 모델 자체(LLM)를 겨냥한 공격 본격화.

2



웨어 시스템 및 EOS 악용

기술지원종료(EOS) 자산 및 방치된 레거시 시스템을 통한 침투 채널 고도화.

3



취약한 클라우드 보안 환경

하이브리드 환경의 설정 오류 및 데브섹옵스(DevSecOps) 부재를 노린 무버먼트 공격.

4



개인정보 유출 발 2차 위협

기존에 유출된 대규모 데이터를 악용한 딥페이크, 스미싱 등 초정밀 타겟팅 공격.

최근 보안 동향

2025년 사이버 위협 전망

1 AI 기반 사이버 위협 및 AI 서비스에 대한 사이버 공격 증가

- AI 기반으로 기존 방어체계를 우회하려는 사이버 공격 시도 증가
- AI 서비스 모델 자체를 공격 대상으로 삼는 기법도 본격화
- 공격 전 과정을 통합한 AI 기반 공격 체계를 통해 사이버 공격의 자동화 · 최적화

사이버 공격자들의 AI 활용이 본격화하면서 2026년에는 AI를 활용한 사이버 공격이 더욱 정교하고 다양화될 것으로 전망된다. 2026년에는 딥페이크 음성·영상 기반 피싱이 실시간 음성 통화 및 화상회의에까지 적용되어, 신뢰 기반 커뮤니케이션을 위협할 가능성이 높다. 또한 Gartner는 오는 2027년까지 AI 기술을 활용한 공격 도구가 사용자 계정 탈취에 소요되는 시간을 절반으로 단축할 것으로 예측했다.

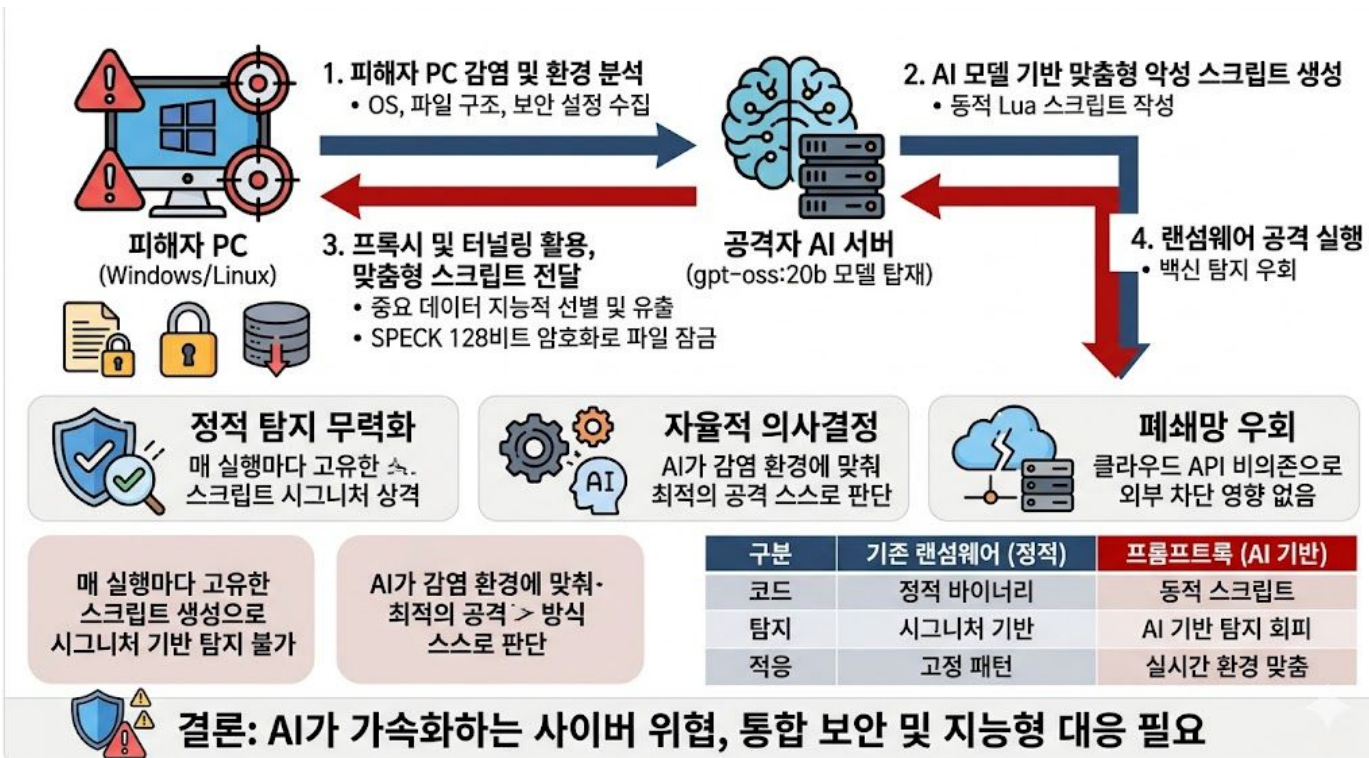
주요 사고 사례 및 동향

- MS, 외부 데이터에 공격 지시를 심어 AI가 정보유출하게 하는 공격자 전략 발표(7월)
- 세계 최초 LLM 기반 악성코드 등장..인공지능 기술의 무기화 본격화(7월)
- 결국 등장한 AI 기반 랜섬웨어...보안업계 우려 현실화(8월)



최근 보안 동향

프롬프트록 (PromptLock)



최근 보안 동향

프롬프트록 (PromptLock)



최근 보안 동향

2026년 사이버 위협 전망

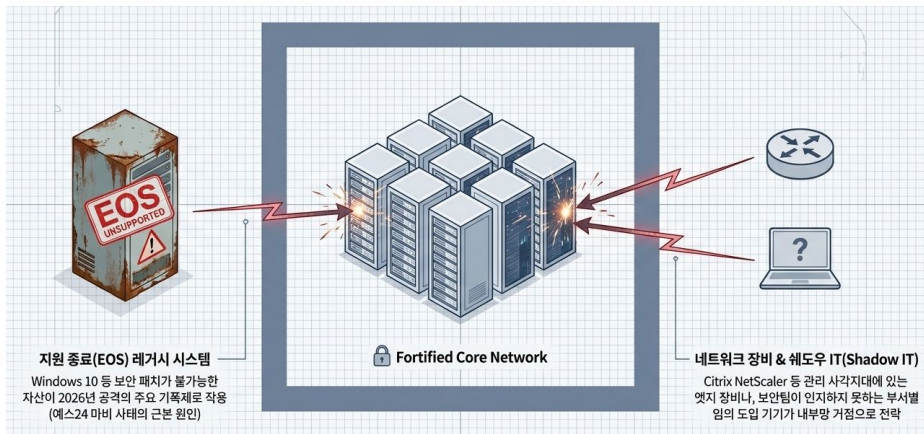
2 EOS와 방치된 미사용 시스템이 해킹 통로로 악용

- EOS*와 패치 관리가 미흡한 시스템을 악용한 침해사고 반복
 - * EOS(End of Support): SW 개발사나 HW 제조사가 더 이상 기술지원을 하지 않는 제품
- IT자산 파악, 레거시 시스템을 네트워크 격리, IT인프라 전반 패치 관리 강화 등 필요

'관리의 빈틈'을 노린 정교한 공격들이 반복적으로 발생할 것으로 보인다. 2026년에는 방치된 '오래된 위험', 즉 EOS된 레거시 시스템에 대한 공격이 크게 증가할 것으로 예상된다. 특히, Windows 10 지원 종료는 이러한 레거시 시스템에 대한 사이버 위협의 기폭제가 될 전망이다.

주요 사고 사례 및 동향

- 예스24 '닷새간 먹통 사태' 원인은?...기술지원 끝난 원도 서버 OS 셧다(6월)
- 네덜란드, 시트릭스 넷스케일러 취약점 공격으로 심각한 피해 입어(8월)
- 롯데카드, 2017년 공개된 취약점에 당했다...(9월)



최근 보안 동향

2026년 사이버 위협 전망-클라우드 환경의 취약 요소 공격 증가

01 AI·자동화 기반 클라우드 침투 공격

AI/LLM을 활용한 클라우드 스캐닝, 취약점 탐지, 권한 탈취의 자동화.
IaaS, PaaS, SaaS, 컨테이너 등 클라우드 기반 AI 인프라가 최우선 표적으로 부상.

02 연쇄 공격 구조 (Chained Exploits) 현실화

개별 단일 취약점을 넘어 [API 취약점 → 컨테이너 취약점 → 서버리스 설정 오류]로 이어지는 연쇄 타격. 한 번의 침투로 다수 리소스에 동시다발적 영향 초래.

03 클라우드 특화 공급망 공격 확대

CI/CD 파이프라인, IaC(Infrastructure as Code) 템플릿, 서드파티 모듈 등
클라우드 네이티브 개발·배포 경로를 악용한 치명적인 악성 코드 삽입 증가.

04 데이터 주권 및 리전(Region) 리스크 대두

멀티 리전 및 하이브리드 환경 보편화에 따른 정책(데이터 전송·암호화·접근제어)
불일치 사고 위험. 국가별 규제 강화 흐름 속 특정 리전 기반 거버넌스 준수 필수.

05 AI-SOC 탐지 회피 및 로그 조작

클라우드 텔레메트리·로그 데이터를 변조하고 AI 기반 보안운영센터(SOC) 탐지
모델을 교묘히 우회하는 위협. 기존 방어 체계의 탐지 및 대응 한계 시험.

최근 보안 동향

2026년 사이버 위협 전망-클라우드 환경의 취약 요소 공격 증가

	과거: 인간 해커 (Human-driven)	미래: 에이전트 AI (Agent-driven)
운영 주체	수동 스캐닝 및 단일 타겟 지정	오케스트레이터 지휘 하에 워커 에이전트(정찰/침투/분석) 분업화
공격 속도	인간의 물리적 시간 한계 및 수면 시간 존재	24시간 무한 루프 공격 (기계적 속도의 스캐닝)
악성코드	단일 패턴의 악성코드 재사용	바이브 코딩(Vibe-Coding): 자연어 명령으로 다형성 탐지 회피 코드 실시간 대량 생성

결론: 수동 분석 중심의 기존 SOC(보안관제)로는 기계 속도의 AI 해킹 방어 절대 불가.

최근 보안 동향

2026년 사이버 위협 전망-클라우드 환경의 취약 요소 공격 증가

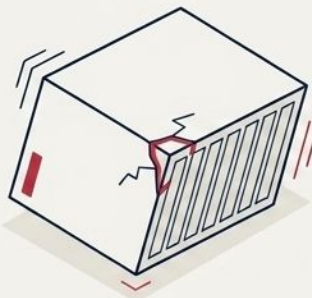
API



연쇄 폭포수 공격

단일 취약점이 아닌
[API 취약점 → 컨테이너 권한 탈취
→ 서버리스 설정 장악]으로
이어지는 전략적 도미노 타격 현실화.

컨테이너



공급망 코드 주입

IaC(코드형 인프라) 템플릿 및
CI/CD 파이프라인 대상
악성 코드 주입 증가.

서버리스 데이터베이스



멀티 리전 리스크

멀티 클라우드 도입에 따른
리전 간(Region-to-Region) 보안 정책
불일치를 노리는 거버넌스 붕괴 타격.

대응 과제: 자산 식별(ASM)부터 실시간 교정까지 이어지는 자동화된 CSPM(클라우드 보안 형상 관리) 도입 필수

최근 보안 동향

2026년 사이버 위협 전망-클라우드 환경의 취약 요소 공격 증가

4 유출된 개인정보를 악용한 2차 사이버 위협

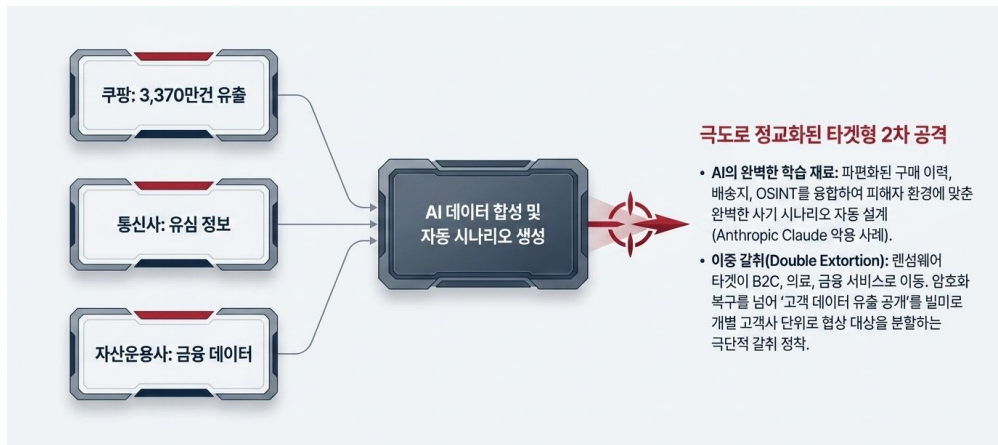
- 해킹, 보안취약점, 내부자 관리부실 등 다양한 요인으로 개인정보 유출 사고 발생
- 개인정보 유출 사태를 악용한 2차 피해 발생 주의 필요

2025년에는 특히 대규모 개인정보 유출 사고도 많이 발생했다. 2월에는 듀오와 GS홈쇼핑이 해킹으로 인해 고객의 이름, 성별, 생년월일, 연락처, 이메일 등을 포함하는 개인정보가 유출됐으며 4월 SKT, 9월 KT 등 이동통신사에서 악성코드 감염으로 인한 대규모 USIM 정보 유출 사고가 발생했다.

특히 11월에는 쿠팡에서 약 3,370만개에 달하는 대량의 회원정보가 퇴사자를 통해 유출되는 사태가 발생했다.

주요 사고 사례 및 동향

- 결혼정보업체도 터졌다... '듀오' 해킹으로 회원 개인정보 유출(2월)
- GS리테일, 홈쇼핑만 158만건 개인정보 유출(2월)
- 알바몬도 털렸다... "개인 이력서 정보 2만2천건 유출"(5월)
- 쿠팡, 퇴사자 인증키 방치... 3370만명 정보 유출 원인 됐다(11월)



최근 보안 동향

대응 방안 : Zero Trust

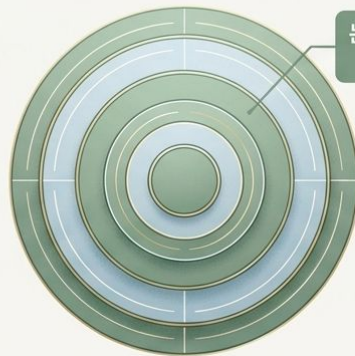
보안 패러다임의 설계: 범정부 N2SF 체계와 제로트러스트 전환



확실적 물리적 망분리

과거: 물리적 경계 방어

- 확실적 물리적 망분리 의존.
- 협력사, 퇴사자, 오픈소스 등 '신뢰받는 경로'를 통한 우회 공격에 무력화.



논리적인 다중 보호막 / MLS 모델

2026년 이후: 데이터 중심 다중 보호막

- **망분리 완화:** 공공 / 금융 망분리를 데이터 중요도에 따른 다중 등급(MLS) 모델로 전면 개편.
- **N2SF 부응:** 클라우드 및 AI 수용을 위해 제로트러스트(Zero Trust) 아키텍처 기반의 논리적 보안으로 전면 재설계.
- **공급망 통제:** 2027년까지 공공 도입 모든 IT 시스템에 대한 SW 구성요소(SBOM) 제출 의무화 확정.

최근 보안 동향

대응 방안 : Cloud Security(MS 예)

Microsoft Cybersecurity Reference Architectures (MCRA) Architecture Diagrams & References

Threat Environment

Ransomware/Extortion, Data Theft, and more



Attack Chain Coverage

Development / DevSecOps

Enabling Security & Business Goals



Infrastructure

Multi-cloud, cross-platform, native controls



Patch Modernization

People

Roles and Risk Management



Role Mapping



Artificial Intelligence (AI) and Security

Zero Trust



Microsoft Security Capabilities



Multi-Cloud & Cross-Platform



Microsoft 365 E5



Build Slide

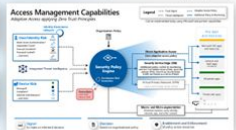
Standards Mapping

Zero Trust Adaptive Access

Security Service Edge (SSE)



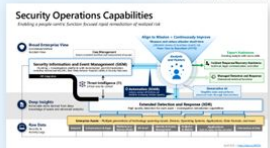
Journey



Privileged Access

Security Operations

(SecOps/SOC)



Operational Technology (OT)

Industrial Control Systems



Device Types



aka.ms/MCRA | aka.ms/MCRA-videos | April 2025

Slide notes have speaker notes & change history

Microsoft
Security Adoption Framework (SAF)

최근 보안 동향

대응 방안 : Zero Trust

01. 명시적 검증 (Verify Explicitly)

사용자의 위치(내부/외부)와 상관없이 모든 접근 요청을 신뢰하지 않고 항상 검증합니다.

- 사용자 신원, 기기 상태, 서비스/워크로드 등 가용한 모든 데이터 포인트를 기반으로 인증 및 인가 수행
- 다중 인증(MFA) 및 지속적인 인증 체계 도입

02. 최소 권한 원칙 (Least Privilege Access)

사용자에게 업무 수행에 꼭 필요한 최소한의 권한만 부여하여 침해 발생 시 피해 확산을 방지합니다.

- 적시 권한 부여(Just-In-Time) 및 적정 권한 부여(Just-Enough-Admin) 적용
- 데이터 분류 및 관리를 통한 세밀한 접근 제어

03. 침해 가정 (Assume Breach)

공격자가 이미 네트워크 내부에 침투해 있다고 가정하고 방어 전략을 수립합니다.

- 네트워크 세분화(Micro-segmentation)를 통해 공격자의 횡적 이동 차단
- 모든 통신 세션의 암호화 및 실시간 모니터링/위협 분석

보안 패러다임의 변화

29

과거: 경계 기반 보안 (Castle-and-Moat)

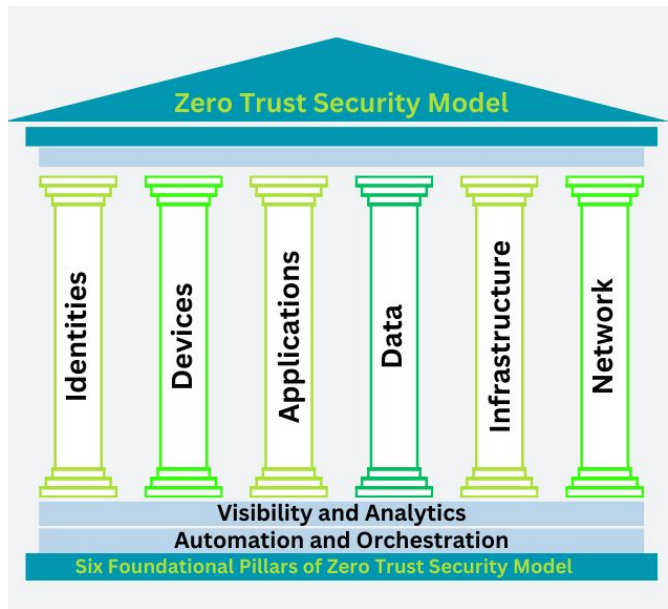
내부는 안전하다는 전제 하에 외부 침입 방위에 집중. 일단 통과하면 내부 리소스에 폭넓은 권한 허용.

미래: 제로 트러스트 (Zero Trust)

리소스 중심의 보안. "절대 신뢰하지 말고 항상 검증하라(Never Trust, Always Verify)"는 철학을 전사적으로 적용.

최근 보안 동향

대응 방안 : Zero Trust

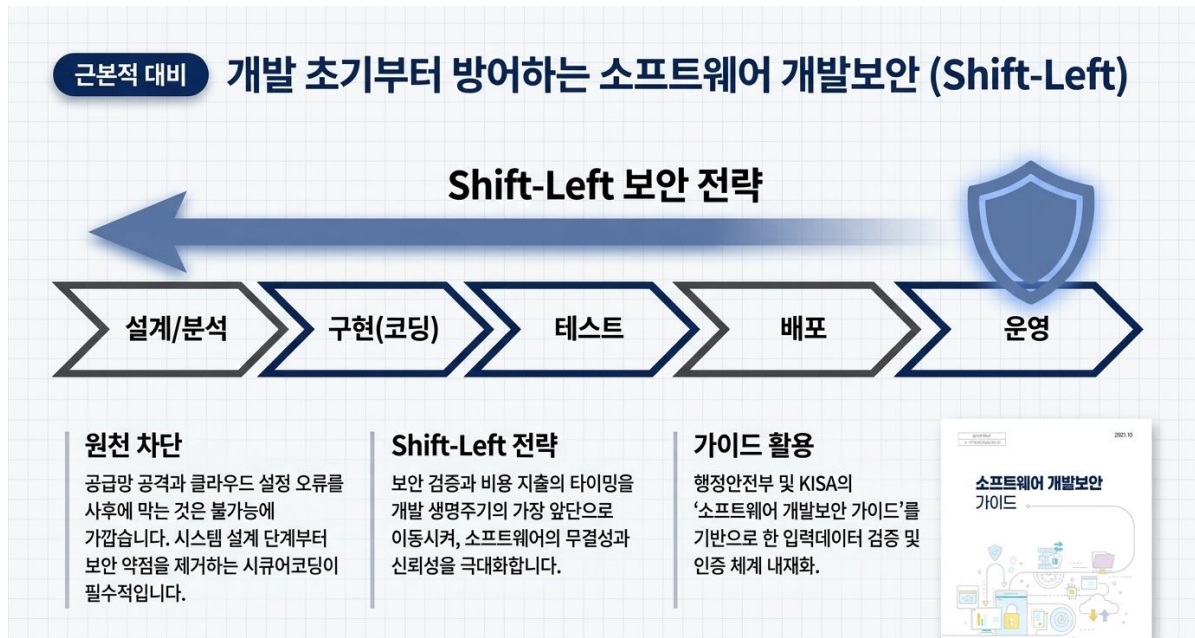


Zero Trust 6 Pillars

1. **사용자 ID (Identities):** 사람, 서비스 계정 등 모든 접근 주체를 포함하며, 강력한 MFA, 실시간 위험 분석으로 신원을 지속 검증하고 JIT 최소 권한을 적용.
2. **디바이스 (Devices):** PC, 모바일 등 리소스 접근에 사용되는 모든 엔드포인트의 상태를 관리. 단말 무결성, 보안 수준, 패치, 악성코드 감염 상태를 실시간 확인 및 통제.
3. **애플리케이션 (Applications):** 클라우드/온프레미스 소프트웨어, 워크로드, 미승인 앱을 제어. 앱 진입/구동 시 권한 검증, 데이터 노출 제한, 상시 행위 분석 수행.
4. **데이터 (Data):** 보호해야 할 핵심 자산. 중요도에 따른 자동 분류 및 라벨링, 저장/전송 중인 데이터 암호화로 유출 리스크 차단.
5. **인프라 (Infrastructure):** 서버 환경, 컨테이너, 클라우드 리소스 및 관리 프로세스를 포함. 설정 오류 실시간 탐지, 인프라 접근 시 세부 권한 통제 및 취약점 방어 수행.
6. **네트워크 (Networks):** 내부 트래픽도 잠재적 위협으로 간주. 마이크로 세그멘테이션으로 네트워크 초세분화 및 격리, 사용자-리소스 간 세션 중심의 종단 간 암호화 적용.

최근 보안 동향

대응 방안: Shift Left

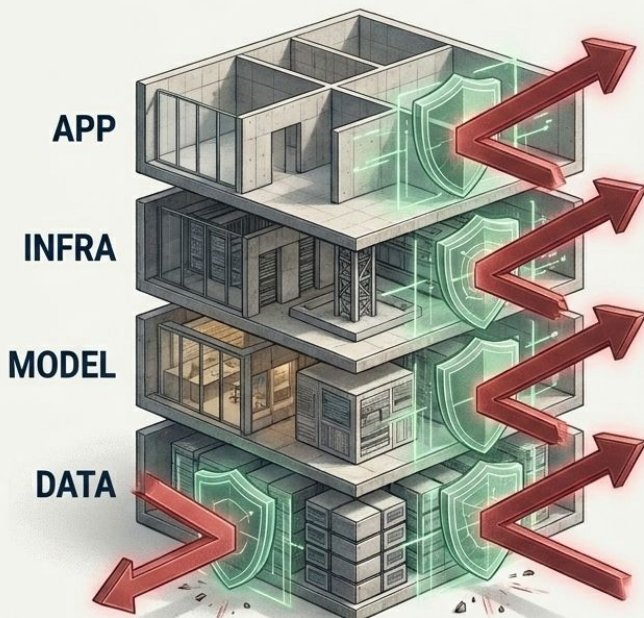


- 시큐어 코딩 준수, 외부 라이브러리 검사, 내부 저장소 접근 제어 등 개발 전반의 보안을 관리
- SAST·DAST 도구를 CI/CD 파이프라인에 통합하여 진단을 자동화하고 보안 수명 주기를 지속 관리
- DevSecOps 시스템 등 사전 점검 도구를 활용해 코드 반영 시 취약점을 즉시 조치

최근 보안 동향

대응 방안: AI 공격에 대한 Intelligent Stack

AX 방어 아키텍처: '인텔리전트 스택' 전 계층 보호 (Trend Micro)



APP (애플리케이션 계층 보호):

WAF(웹방화벽)로 탐지 불가능한 '간접 프롬프트 주입(Indirect Prompt Injection)' 등 에이전트 권한 탈취 원천 차단.

INFRA (인프라 계층 보호):

값비싼 GPU 자원 하이재킹 및 벡터 데이터베이스(Vector DB) 인젝션 차단.

MODEL (모델 계층 보호):

AI 모델 탈취 방어 및 미세 변조를 통한 오판 유도(적대적 공격) 방어.

DATA (데이터 계층 보호):

AI 학습 데이터 오염(Data Poisoning) 및 RAG(검색 증강 생성) 환경 내 악성 문서 주입 원천 차단.

최근 보안 동향

대응 방안: AI 공격에 대한 방어

기계 대 기계의 싸움: 자율형 방어(Agentic Security) 도입 필수

[수동 방어 (Human-in-the-Loop)]



- 대응 속도: 수 분 ~ 수 시간 소요 (인간의 피로도 누적)
- 방어 방식: 단일 알럿(Alert) 기반 수동 로그 분석
- 한계: 24시간 무한 루프로 쏟아지는 AI 기반 공격 속도를 물리적으로 감당 불가

[자율형 방어 (Agentic Defense)]



- 대응 속도: 밀리초(ms) 단위 실시간 격리
- 방어 방식: AI-SOC 구축. AI가 수만 개의 로그를 1차 분석하고 방어 에이전트가 네트워크 격리 및 패치 자동 수행.
- 에이전트 통제: 기업 내 도입된 모든 AI 에이전트들에 제로트러스트 기반 '기계 ID(Machine ID)' 부여 및 권한 최소화 강제.

결론: 인간의 수동 분석으로는 기계 속도의 AI 해킹을 방어할 수 없습니다.
AI 공격의 무한 루프를 끊어낼 수 있는 '**자동화된 기계적 방어**' 체계 확립이 생존의 필수 조건입니다.

Secure Coding Education

- # Secure Coding

Education and Employment

- # Education

- ## Building Robust and Resilient Software



소프트웨어 개발보안

개요 : 보안모델

[그림 3] 로봇 서비스의 보안위협



[그림 4] 로봇 서비스의 보안요구사항



글로벌 사이버보안 규제를 분석하여 로봇 시스템에서 발생할 수 있는 위협을 사전에 식별하여, 규제 요구사항을 충족할 수 있도록 로봇 제조사 및 운영자가 실질적으로 활용할 수 있는 가이드를 제공

소프트웨어 개발보안

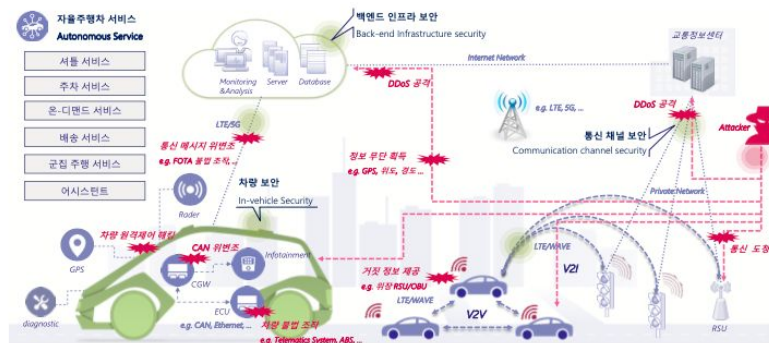
개요 : 보안모델

그림 3 자율주행차 서비스 구성도



자율주행차 보안모델(2025-04-24)

그림 4 자율주행차 서비스 보안위협



융합으로 인하여 기존 ICT 환경에서 발생했던 사이버 공격들이 자동차 환경으로 전이되고 있다. 자동차의 안전은 운전자와 승객 더 나아가 도로 위에 존재하는 모든 사물들의 안전과 직결되므로 자동차를 대상으로 수행되는 사이버 공격들에 대한 방어 태세를 완비해야 한다.

소프트웨어 개발보안

개요: 보안모델

소프트웨어 개발보안(Secure SDLC) 3대 방법론 핵심 비교



NotebookLM

소프트웨어 개발보안

소프트웨어 개발 보안 개요

목적

- ‘행정기관 및 공공기관 정보시스템 구축·운영 지침(행정안전부고시 제2021-3호)’에 따라 정보시스템을 구축·운영함에 있어 소프트웨어 보안약점이 없도록 안전한 소프트웨어 개발을 위한 가이드 제시

대상

- 소프트웨어(SW) 개발자·운영자

범위

- 신규로 개발되거나 유지보수로 변경되는 소프트웨어 개발 시 적용
- ※ 행정기관 등이 추진하는 정보화사업 중 소프트웨어 개발 프로세스의 전체 단계 (분석·설계·구현·테스트)에 초점

소프트웨어 개발보안

소프트웨어 개발 보안 개요

진단 의무 대상 및 범위

정보시스템 감리 대상 정보화사업

전자정부법 시행령 제71조 2항

모바일 전자정부 서비스

- 모바일 웹, 모바일 앱,
하이브리드 앱 전체 포함

설계단계 산출물 및 소스코드 전체

신규 개발 사업 → **전체(100%)** 적용

유지보수 사업 → **변경된 부분만** 적용

 **예외 사항: 상용 소프트웨어 제외**

점검 기준 대시보드

20개

설계단계
(소프트웨어 설계단계
보안설계 기준)

49개

구현단계
(소프트웨어 구현단계
보안약점 제거 기준)

26개

모바일 앱
보안약점

20개

모바일
보안취약점

주체별 역할 및 책임



발주기관
(행정·공공기관)

- 재안요청서(RFP)에
'SW 개발보안 적용' 의무 명시
- 사업중료 시 결과를 및
증빙서류 최종 확인



사업자
(개발자)

- 자체적 SW 보안약점 진단
및 제거 (시장요구 이행)
- 가이드라인 참조 및 개발
투입 전 보안 교육 실시



감리법인 (또는 진단원)

- 설계/구현 단계 SW보안약점
제거 여부 진단
- 국가보안기술연구소 **CC인증**
받은 진단도구 필수 사용
- 전문 자격을 갖춘 '진단원'
우선 배치 권고

소프트웨어 개발보안

소프트웨어 개발 생명주기 모델



정의 단계 WHAT

무엇을 처리하는 소프트웨어를 개발할 것인지 명확히 정의하고 타당성을 검토하는 준비 과정입니다.

- 타당성 검토
- 개발 계획 수립
- 요구사항 분석



개발 단계 HOW

어떻게 구현할 것인가에 초점을 맞추어 실제 아키텍처를 설계하고 코드로 구현 및 검증합니다.

- 시스템 및 상세 설계
- 구현 (개발)
- 테스트 및 검증



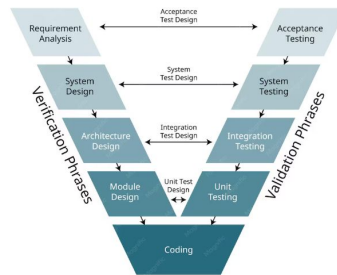
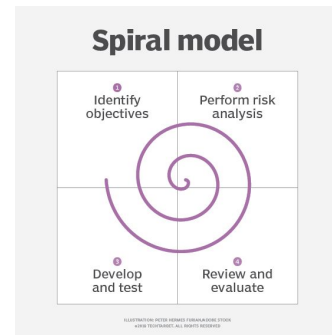
유지보수 단계 CHANGE

운영 중 발생하는 환경 변화나 요구에 따라 소프트웨어를 지속적으로 적용, 수정 및 관리합니다.

- 운영 및 유지보수
- 시스템 변경 대응
- 단계적 폐기

소프트웨어 개발보안

SDLC에 따른 개발 방법론 이해



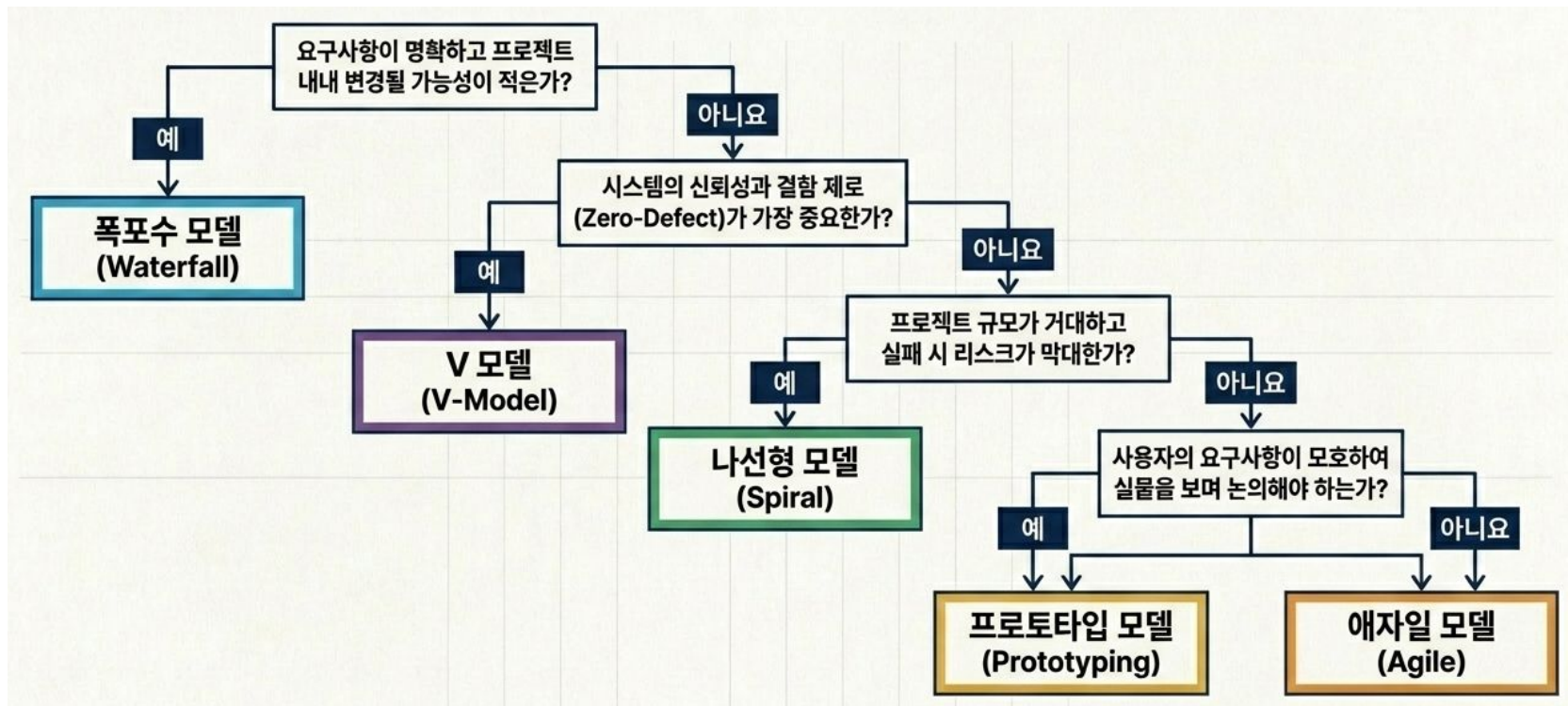
소프트웨어 개발보안

SDLC에 따른 개발 방법론 이해



소프트웨어 개발보안

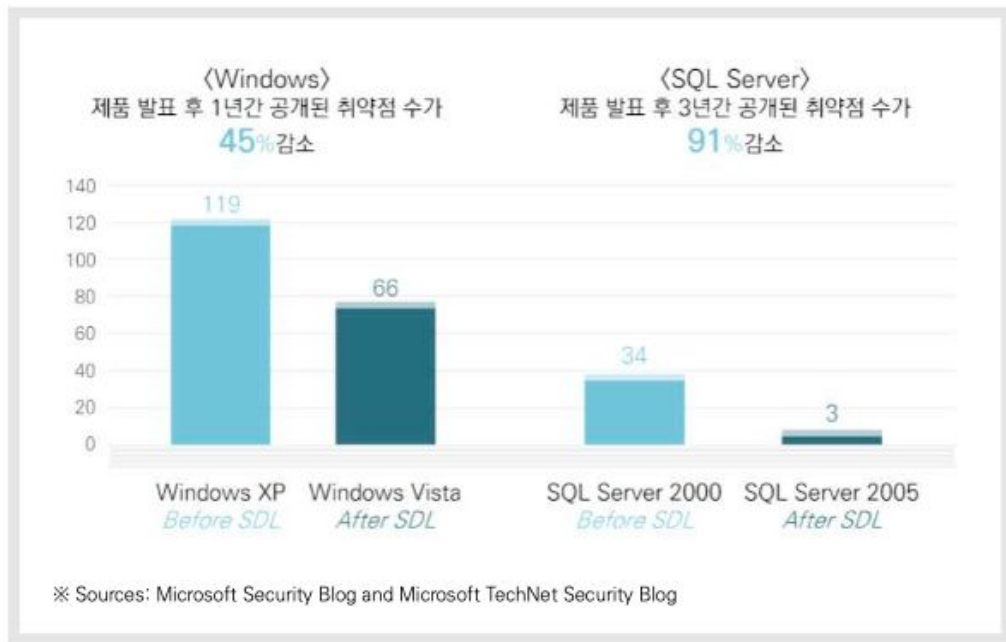
개발 방법론 채택 프레임워크



소프트웨어 개발보안

소프트웨어 개발보안 적용 효과

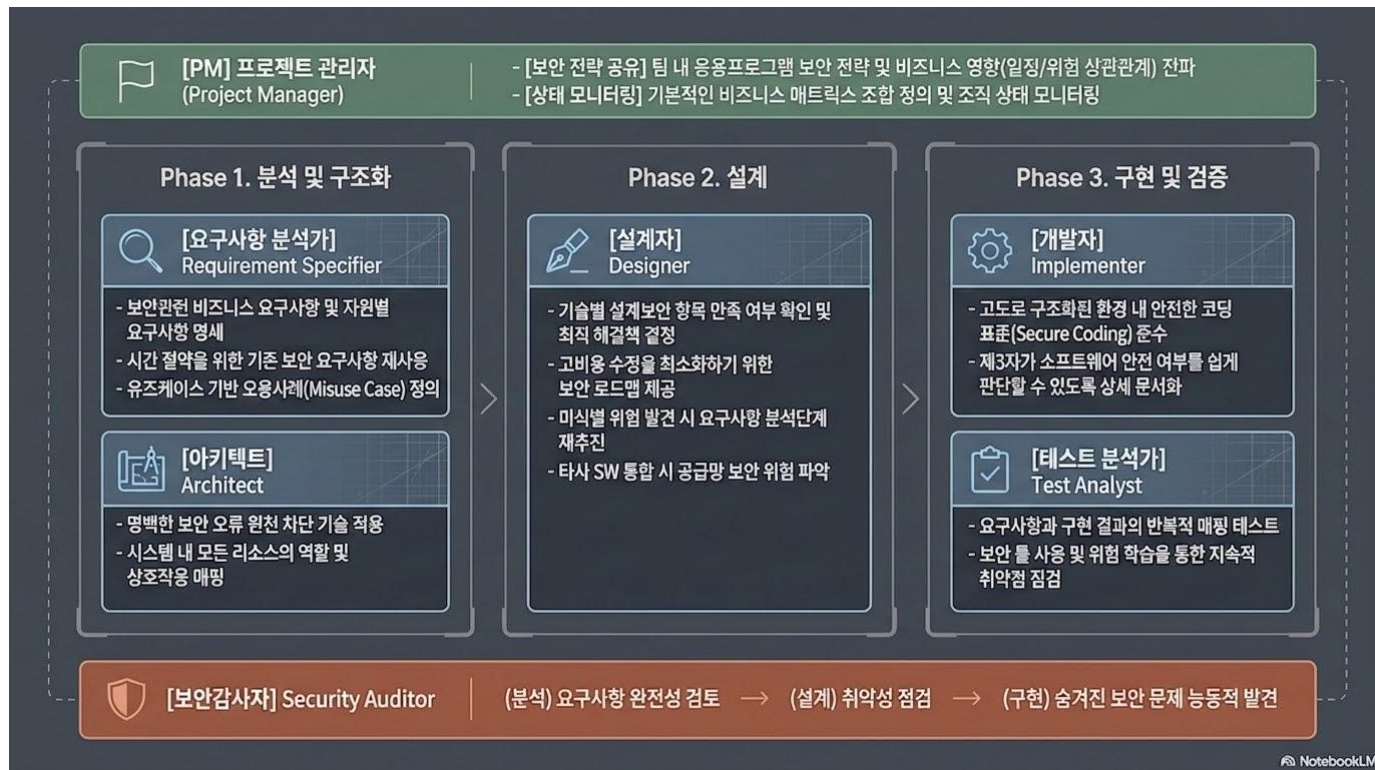
MS(MicroSoft사)에서는 소프트웨어 개발보안 방법론을 적용하여 프로젝트를 수행한 경우, 취약점이 대폭 감소하여 보안패치와 같은 유지보수 비용이 확연하게 감소하였다고 발표



NIST에서 제품출시단계에 발견되는 결함을 제거하기 위해서는 30배의 비용이 요구된다는 자료를 발표

소프트웨어 개발보안

프로젝트 참여 직무별 보안활동



소프트웨어 개발보안

분석·설계단계 보안강화 활동

구분	설계단계	구현단계
입력 데이터 검증 및 표현 (10개)	DBMS 조회 및 결과 검증	• SQL 삽입
	XML 조회 및 결과 검증	• XML 삽입 • 부적절한 XML 외부개체 참조
	디렉토리 서비스 조회 및 결과 검증	• LDAP 삽입
	시스템 자원 접근 및 명령어 수행 입력값 검증	• 코드 삽입 • 경로조작 및 자원삽입 • 서버사이드 요청 위조 • 운영체제 명령어 삽입
	웹 서비스 요청 및 결과 검증	• 크로스사이트 스크립트
	웹 기반 중요 기능 수행 요청 유효성 검증	• 크로스사이트 요청 위조
	HTTP 프로토콜 유효성 검증	• 신뢰되지 않은 URL 주소로 자동접속 연결 • HTTP 응답분할
	허용된 범위내 메모리 접근	• 포맷스트링 삽입 • 메모리 버퍼 오버플로우
	보안기능 입력값 검증	• 보안기능 결정에 사용되는 부적절한 입력값 • 정수형 오버플로우 • Null Pointer 역참조
	업로드 · 다운로드 파일검증	• 위험한 형식 파일 업로드 • 부적절한 전자서명 확인 • 무결성 검사 없는 코드 다운로드

설계 10개 항목

구현 49개 항목

소프트웨어 개발보안

분석·설계단계 보안강화 활동

설계 10개 항목
구현 49개 항목

구분	설계단계	구현단계
보안 기능 (8개)	인증 대상 및 방식	• 서버사이드 요청 위조 • 적절한 인증 없는 중요기능 허용 • 부적절한 인증서 유효성 검증 • DNS lookup에 의존한 보안결정
	인증 수행 제한	• 반복된 인증시도 제한기능 부재
	비밀번호 관리	• 하드코딩된 중요정보 • 취약한 비밀번호 허용
	중요자원 접근통제	• 부적절한 인가 • 중요한 자원에 대한 잘못된 권한 설정
	암호키 관리	• 하드코딩된 중요정보 • 주석문 안에 포함된 시스템 주요 정보
	암호연산	• 취약한 암호화 알고리즘 사용 • 충분하지 않은 키 길이 사용 • 적절하지 않은 난수 값 사용 • 부적절한 인증서 유효성 검증 • 솔트 없이 일방향 해쉬함수 사용
	중요정보 저장	• 암호화 되지 않은 중요정보 • 사용자 하드디스크에 저장되는 쿠키를 통한 정보 노출
	중요정보 전송	• 암호화 되지 않은 중요정보
에러 처리 (1개)	예외처리	• 오류 메시지 정보노출
세션 통제 (1개)	세션통제	• 잘못된 세션에 의한 데이터 정보 노출

소프트웨어 개발보안

분석·설계단계 보안강화 활동

security pipeline

★ 핵심 대조표: 설계단계 vs 구현단계 개발보안

비교 기준	설계단계 (Design)	구현단계 (Implementation)
핵심 목표	논리적 위협 예측 및 차단 통제 수립	소스코드 단위의 물리적 취약점 제거
주요 관점	시스템의 전체적인 구조와 인터페이스	개별 모듈의 로직과 데이터 처리
핵심 활동	공격 표면 분석, 위협 모델링, 보안설계서 검토	시큐어 코딩 가이드 준수, 금지 API 차단, 정적 분석
주요 산출물	보안설계서, 유즈케이스 명세서, 위협 모델링 결과	안전한 소스코드, 정적 분석 결과서, 취약점 조치 보고서
도구 및 기법	스트라이드(STRIDE) 모델, 데이터 흐름도(DFD)	소스코드 보안약점 진단 도구 (CC인증), IDE 플러그인

소프트웨어 개발보안

기능설계 시 보안설계 적용 방법

표 3-3 설계항목 적용계획서(예)

유형	입력데이터 검증 및 표현	요구사항번호	SR1-1
설계항목	DBMS 조회 및 결과 검증		
보안대책	DBMS 조회시 질의문(SQL) 내 입력값과 그 조회결과에 대한 유효성 검증방법(필터링 등) 설계 및 유효하지 않은 값에 대한 처리방법을 설계해야 한다.		
설계항목 적용 계획	애플리케이션에서 DB연결을 위해 사용되는 계정은 "애플리케이션명_시리얼번호"로 설정하며, 해당 계정에 대해서는 "애플리케이션명_테이블명"에 대해 조회, 수정, 삭제, 업데이트 권한만 설정한다.		
비고	표준코딩정의서에서 정의		

‘행정기관 및 공공기관 정보시스템 구축·운영 지침(별표3)’은 정보처리시스템 구축 시 보안설계 기준을 정의한다. 이 설계항목들을 설계단계에서 반영하기 위한 계획 수립이 필요하며, [표3-3]은 이를 위한 ‘보안요구항목 적용계획서’ 양식이다.

소프트웨어 개발보안

기능설계 시 보안설계 적용 방법

[설계항목 적용예 1_유즈케이스 다이어그램]

유즈케이스 ID: 사용자 로그인	
사전조건	포스트잇 프로그램을 가동한다.
시나리오	

[주요 이벤트 경로]

사용자는 포스트잇 프로그램을 가동한다.
자동 로그인인 실행되어 사용자는 바로 자신의 개인화된 화면으로 이동한다.

[대안 또는 예외 경로]

- 로그인 옵션이 수동 로그인으로 적용되어 있을 때:
- 프로그램은 아이디/비밀번호를 묻는 창을 띄운다.
- 프로그램은 서버에서 아이디/비밀번호를 검증한다.
- 아이디/비밀번호가 잘못되었을 경우 1.a로 돌아간다.

첫번째 로그인일 경우

- 프로그램은 아이디/비밀번호를 묻는 창을 띄운다.
- 프로그램은 서버에서 아이디/비밀번호를 검증한다.
- 아이디/비밀번호가 잘못되었을 경우 2.a로 돌아간다.
- 사용자에게 자동 로그인 옵션과 수동 로그인 옵션 중 하나를 선택하도록 묻는다.
- 사용자가 입력 옵션 선택을 하지 않을 경우, 기본적으로 자동 로그인 옵션을 선택하도록 한다.

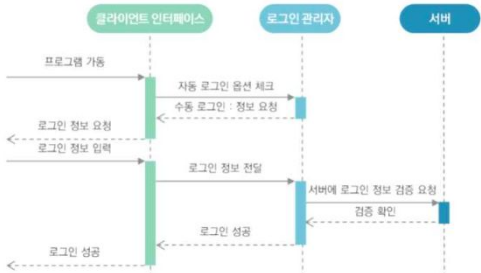
사후조건	사용자는 로그인에 성공한다.
------	-----------------

설계항목	주요 점검사항	비고
SR1-1 DBMS 조회 및 결과 검증	• 사용자가 입력한 아이디/비밀번호가 SQL 삽입을 일으키지 않도록 해야 한다.	FR-001 공통적용
SR2-2 인증수행제한	• 인증시도 횟수가 제한 되도록 해야 한다.	FR-002 공통적용
SR2-8 중요정보 전송	• 아이디/비밀번호는 암호화된 통신채널을 이용하여 전송되어야 한다.	
SR3-1 예러처리	• 에러메시지에 시스템의 정보가 노출되지 않아야 한다.	

※ FR-001 기능은 SQL삽입 필터링을 위한 필터링 기능이라고 가정
※ FR-002 기능은 인증시도 횟수제한 기능이라고 가정

[설계항목 적용예 2_순차 다이어그램]

[순차 다이어그램: 사용자 로그인 - 수동 로그인]



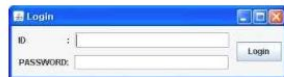
* 설계항목(예시)		
설계항목	주요 점검사항	비고
SR1-1 DBMS 조회 및 결과 검증	• 사용자가 입력한 아이디/비밀번호가 SQL삽입을 일으키지 않도록 해야 한다.	FR-001 공통적용
SR2-2 인증수행제한	• 인증시도 횟수가 제한 되도록 해야 한다.	FR-002 공통적용
SR2-8 중요정보 전송	• 아이디/비밀번호는 암호화된 통신채널을 이용하여 전송되어야 한다.	
SR3-1 예러처리	• 에러메시지에 시스템의 정보가 노출되지 않아야 한다.	

※ FR-001 기능은 SQL삽입 필터링을 위한 필터링 기능이라고 가정
※ FR-002 기능은 인증시도 횟수제한 기능이라고 가정

[설계항목 적용예 3_화면설계서]

ID	SP-LOGIN-01		
업무시스템	포스트잇 클라이언트	화면명	사용자 로그인 화면
업무기능	사용자 로그인 정보 입력	관련 TABLE	
단위시스템	사용자 로그인		

A. 화면



B. 처리 개요

사용자의 로그인 정보를 입력 받는 화면을 구성한다. 사용자에게 입력 받는 로그인 정보는 ID와 PASSWORD 이다. 사용자 입력 후 Login 버튼을 누르면 유즈케이스 '사용자 로그인'의 대안 또는 예외 경로로 로그인 정보를 검증한다.

C. 화면 입/출력 정보일람

번호	I/O	이벤트	포인팅	기능(링크 포함)
1	I	입력	ID	
2	I	입력	PASSWORD	
3	I	클릭	Login	입력된 ID/PASSWORD로 로그인 시도

D. 업무 흐름

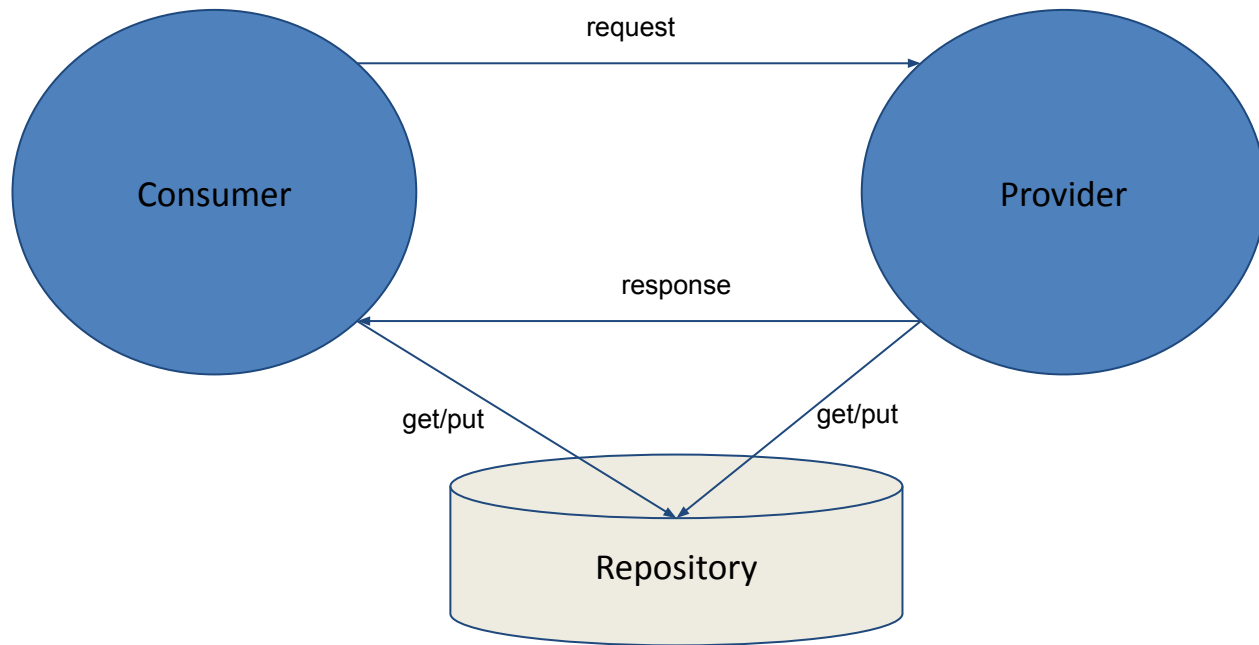
- 사용자는 ID/PASSWORD 입력창에 각각 자신의 로그인 정보를 입력한다.
- PASSWORD 입력창에 입력된 바를 바로 보이지 않고 (d-o) 또는 (e-a)로써 표시된다.
- 개인 정보 입력 후 Login 버튼을 누르면 시스템은 사용자의 로그인 정보를 이용하여 로그인도를 시도한다.

설계항목	주요 점검사항	비고
SR1-1 DBMS 조회 및 결과 검증	• 사용자가 입력한 아이디/비밀번호가 SQL삽입을 일으키지 않도록 해야 한다.	FR-001 공통적용
SR2-2 인증수행제한	• 인증시도 횟수가 제한 되도록 해야 한다.	FR-002 공통적용
SR2-8 중요정보 전송	• 아이디/비밀번호는 암호화된 통신채널을 이용하여 전송되어야 한다.	
SR3-1 예러처리	• 에러메시지에 시스템의 정보가 노출되지 않아야 한다.	

※ FR-001 기능은 SQL삽입 필터링을 위한 필터링 기능이라고 가정
※ FR-002 기능은 인증시도 횟수제한 기능이라고 가정

소프트웨어 개발보안

위치에 따른 보안 점검 항목 정리

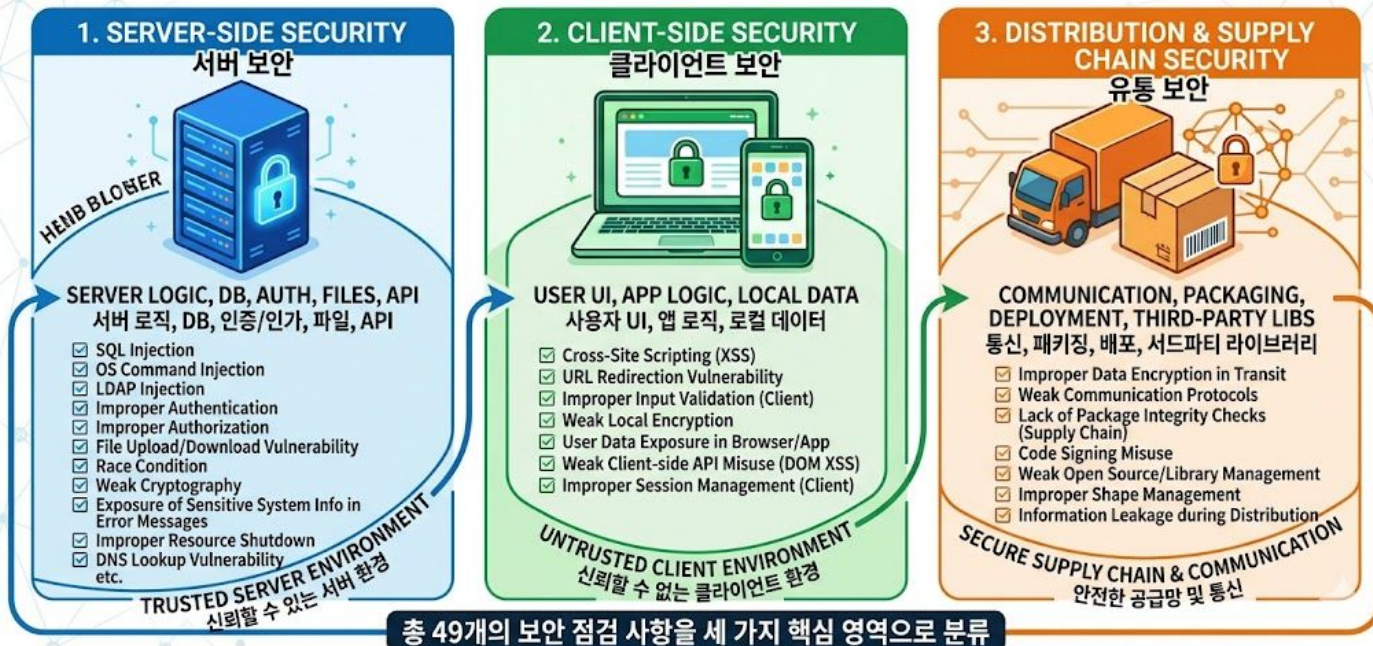


소프트웨어 개발보안

위치에 따른 보안 점검 항목 정리

구현보안점검 사항 49개 범주별 정리 (서버, 클라이언트, 유통)

49 IMPLEMENTATION SECURITY CHECKS: CATEGORIZED BY SERVER, CLIENT, DISTRIBUTION



소프트웨어 개발보안

구현단계 시큐어코딩 가이드

49개 보안약점 아키텍처 맵 (The 49-Item Blueprint)



대부분의 기존 시큐어코딩 기준들은 설계단계에서부터 고려되어야 하며, 개발단계에 코딩 규칙을 준수하는 것만으로도 취약점 제거 가능.

소프트웨어 개발보안

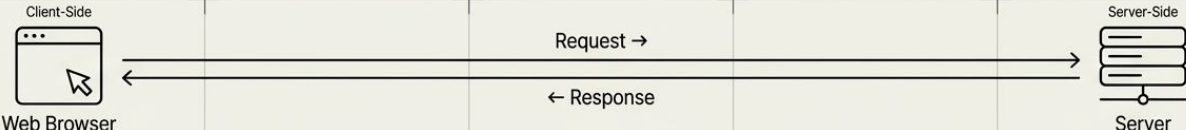
구현단계 시큐어코딩 가이드

인젝션 매트릭스 (Injection Family)				
PANEL 01	PANEL 02	PANEL 03	PANEL 04	PANEL 05
SQL 삽입 대상: DB 데이터 위치: DB 쿼리 조합부 해결: 파라미터화 질의 (PreparedStatement) 사용.	운영체제 명령어 삽입 대상: 시스템 제어권 위치: 외부 프로세스 실행부 해결: 명령어 생성 시 외부 입력 값 배제, 화이트리스트 필터링.	코드 삽입 대상: 동적 스크립트 실행 위치: ScriptEngineManager 등 해결: 동적코드 실행 금지, 불가피할 경우 화이트리스트 적용.	XML 삽입 대상: XML 파서 로직 위치: XPath/XQuery 생성부 해결: 파라미터화된 XPath 쿼리 사용, 특수문자 이스케이프.	LDAP 삽입 대상: 디렉토리 서비스 위치: LDAP 필터 조합부 해결: DN 및 검색 필터에 사용 되는 입력값 필터링.
[위협]: <code>query = "SELECT * FROM users WHERE id='" + id + "'";</code>	[위협]: <code>Runtime.getRuntime().exec("cmd.exe /c " + input);</code>	[위협]: <code>engine.eval(userInput);</code>	[위협]: <code>XPath.compile("//users/user[login/text()=' " + input + "']");</code>	[위협]: <code>search(base, "(uid=" + user + ")", controls);</code>
[안전]: <code>query = "SELECT * FROM users WHERE id=?"; pstmt.setString(1, id);</code>	[안전]: <code>if(allowedCmds.contains(input)) { Runtime.getRuntime().exec("cmd.exe /c " + input); }</code>	[안전]: <code>if(safeList.contains(userInput)) engine.eval(userInput);</code>	[안전]: <code>// ?를 사용한 파라미터화 쿼리 바인딩</code>	[안전]: <code>// JNDI 특수문자(\, *, *, (,), \0) 이스케이프 처리</code>

소프트웨어 개발보안

구현단계 시큐어코딩 가이드

크로스사이트 & 라우팅 (Browser & Routing Exploits)

 Client-Side Web Browser Request → ← Response Server-Side Server				
PANEL 01	PANEL 02	PANEL 03	PANEL 04	PANEL 05
크로스사이트 스크립트(XSS)	크로스사이트 요청 위조(CSRF)	서버사이드 요청 위조(SSRF)	신뢰되지 않은 URL 자동접속	HTTP 응답 분할
대상: 세션 쿠키, 브라우저 제어 방식: 검증없는 입력이 HTML로 출력되어 스크립트 실행 해결: 출력 전 HTML 엔티티 인코딩.	대상: 사용자 권한 상태 방식: 인증된 세션을 동용해 위조된 요청 전송 해결: 상태 변경 요청 시 CSRF 토큰 검증.	대상: 내부망 서버 방식: 서버가 신뢰되지 않은 URL로 대신 요청을 보냄 해결: 입력된 URL을 내부 화이트리스트 IP/도메인과 대조.	대상: 피싱 피해 방식: 리다이렉트 URL 변조 해결: 리다이렉트 대상 URL 하드코딩 또는 인덱스 매핑.	대상: 브라우저 캐시, 응답 헤더 방식: CR/LF 문자로 응답 헤더 조작 해결: 헤더 값에 개행문자(\r, \n) 제거.
<pre>out.print("User: " + request.getParameter("name"));</pre>	<pre>// 토큰 검증 없는 POST 요청 처리</pre>	<pre>URL url = new URL(request.getParameter("url")); url.openConnection();</pre>	<pre>response.sendRedirect(request.getParameter("target"));</pre>	<pre>response.setHeader("Location", input);</pre>
<pre>out.print("User: " + escapeHtml(request.getParameter("name")));</pre>	<pre>if(request.getParameter("csrf_token").equals(sessionToken)) {...}</pre>	<pre>// 화이트리스트 도메인 확인 후 연결</pre>	<pre>response.sendRedirect(safeURLs.get(request.getParameter("id")));</pre>	<pre>response.setHeader("Location", input.replaceAll("[\r\n]", ""));</pre>

소프트웨어 개발보안

구현단계 시큐어코딩 가이드

웹 애플리케이션 보안 공격 비교: XSS vs. CSRF vs. SSRF

**공격 실행 위치(사용자 브라우저 vs 취약한 서버)와 피해 대상에 따라 구분됨

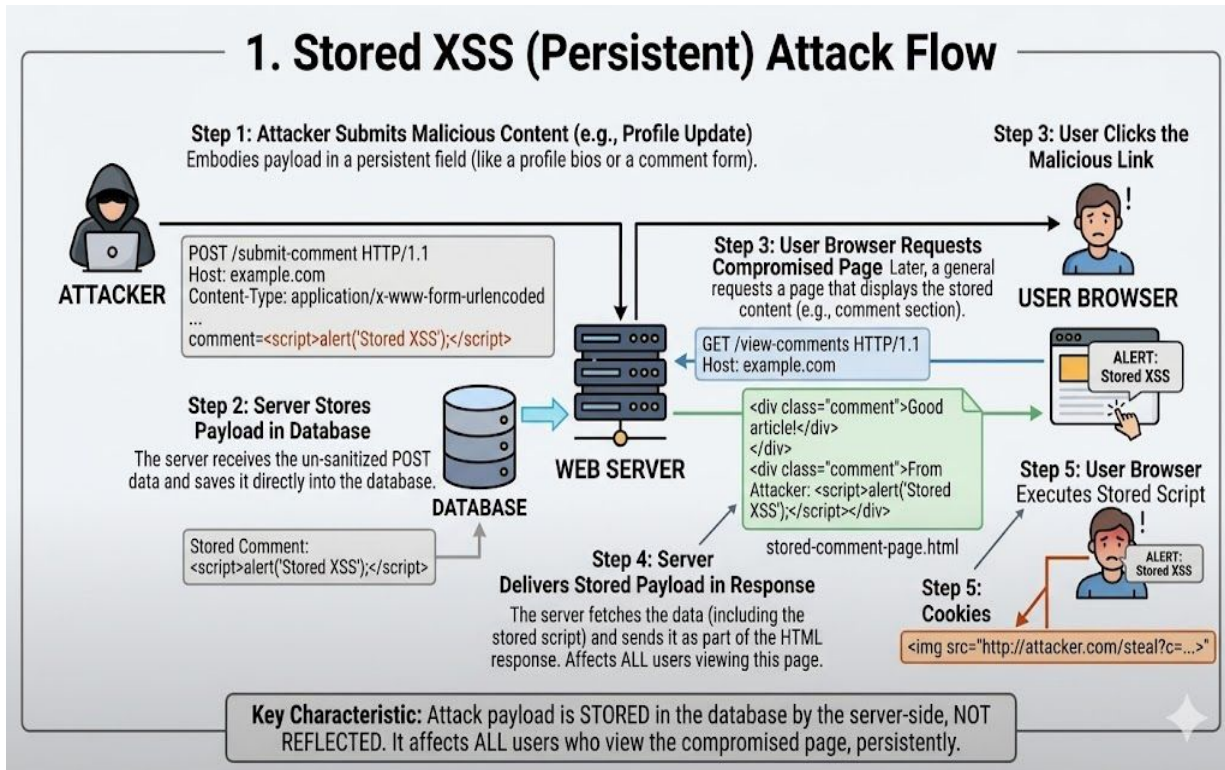


핵심 차이점 비교 요약

항목	크로스사이트 스크립트 (XSS)	크로스사이트 요청 위조 (CSRF)	서버사이드 요청 위조 (SSRF)
공격 실행 위치	사용자 브라우저 (Client)	사용자 브라우저 (Client)	취약한 웹 서버
주요 피해 대상	웹서비스 이용자	웹서비스 이용자 및 서버 권한	웹 서버 및 내부 네트워크 시스템
핵심 메커니즘	브라우저 내 악성 코드 실행	브라우저의 쿠키 자동 전송 악용	서버의 무검증 URL 요청 처리 악용
공격 목적	세션 탈취, 데이터 조취	사용자 권한을 통한 강제 액션	내부망 침투, 폐쇄 데이터 탈취

소프트웨어 개발보안

구현단계 시큐어코딩 가이드(추가설명)



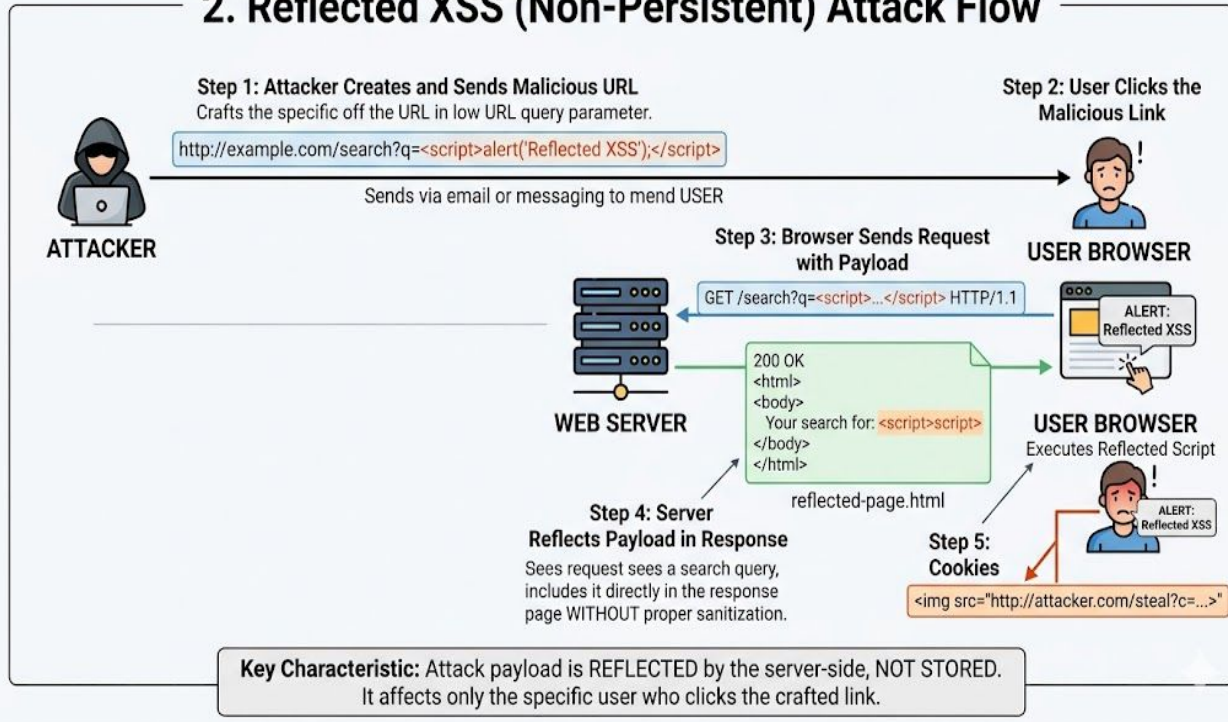
[Stored XSS 다이어그램 설명]

1. 공격자 스크립트 주입 (Step 1): 공격자가 게시판/방명록 등 서버 저장 기능에 악성 스크립트 (<script>...)를 포함하여 제출.
2. 서버 저장 (Step 2, 3): 웹 서버가 입력 검증 없이 악성 스크립트를 데이터베이스(DB)에 저장.
3. 일반 사용자 요청 (Step 4): 일반 사용자가 악성 스크립트가 포함된 페이지(예: 댓글 목록)를 요청.
4. 악성 스크립트 포함 응답 (Step 5): 서버가 DB에서 악성 스크립트가 포함된 데이터를 가져와 사용자 브라우저에 전송.
5. 사용자 브라우저 실행 (Step 6): 사용자 브라우저가 응답 렌더링 중 악성 스크립트를 실행하여 세션 쿠키 탈취, 가짜 로그인 창 표시 등의 피해 발생.

소프트웨어 개발보안

구현단계 시큐어코딩 가이드(추가설명)

2. Reflected XSS (Non-Persistent) Attack Flow

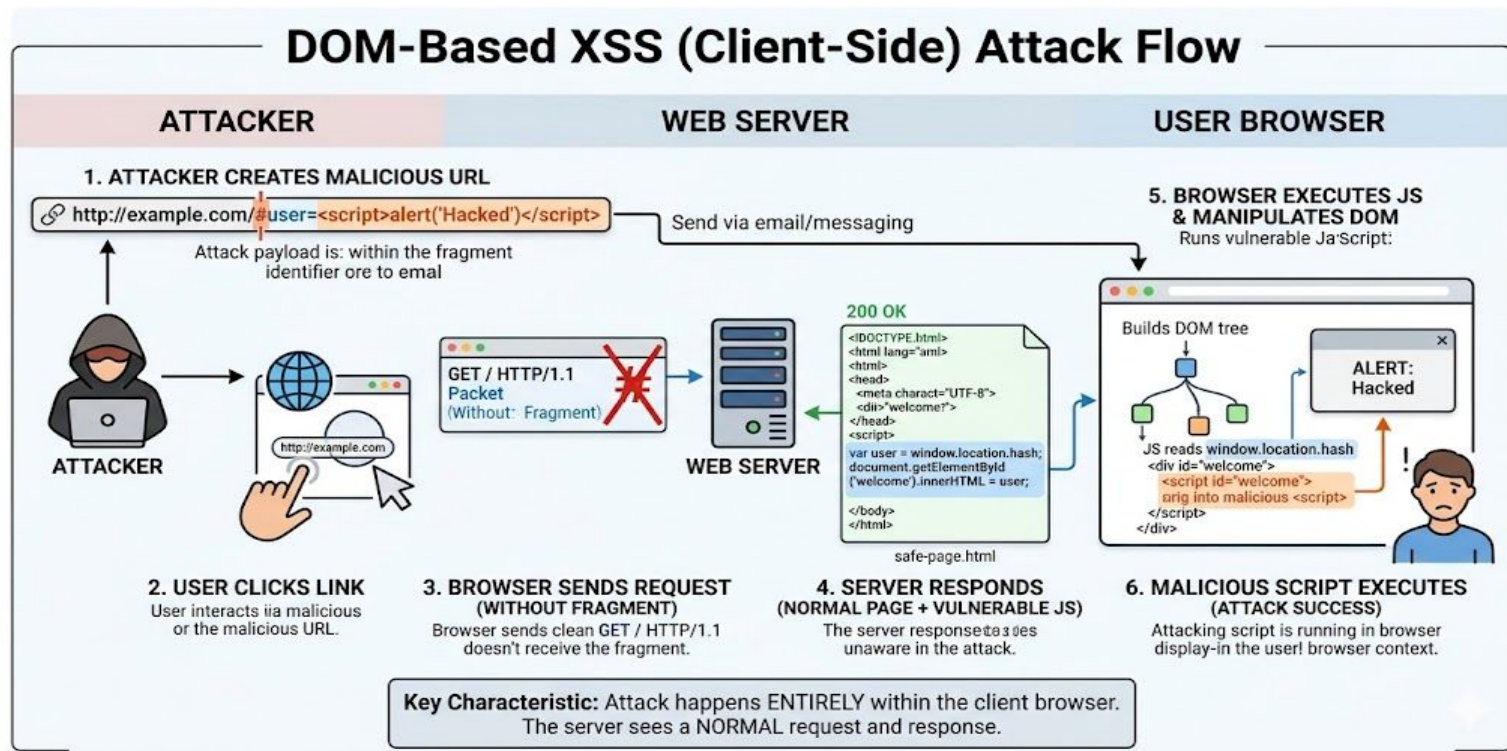


[Reflected XSS 다이어그램 설명]

1. 악성 URL 생성 및 전달 (Step 1): 공격자는 악성 스크립트가 포함된 특수 URL을 생성하여(예: `search?q=<script>...`) 피해자에게 보냅니다.
2. 사용자 링크 클릭 (Step 2): 피해자가 해당 링크를 클릭합니다.
3. 서버 요청 (Step 3): 사용자 브라우저는 악성 스크립트 파라미터를 서버에 전송합니다.
4. 스크립트 '반사' 응답 (Step 4): 서버는 요청 파라미터의 악성 스크립트를 검증 없이 HTML 응답에 포함시켜 사용자에게 반사합니다.
5. 사용자 브라우저 실행 (Step 5): 사용자 브라우저가 반사된 악성 스크립트를 실행하며 Stored XSS와 같은 피해가 발생합니다.

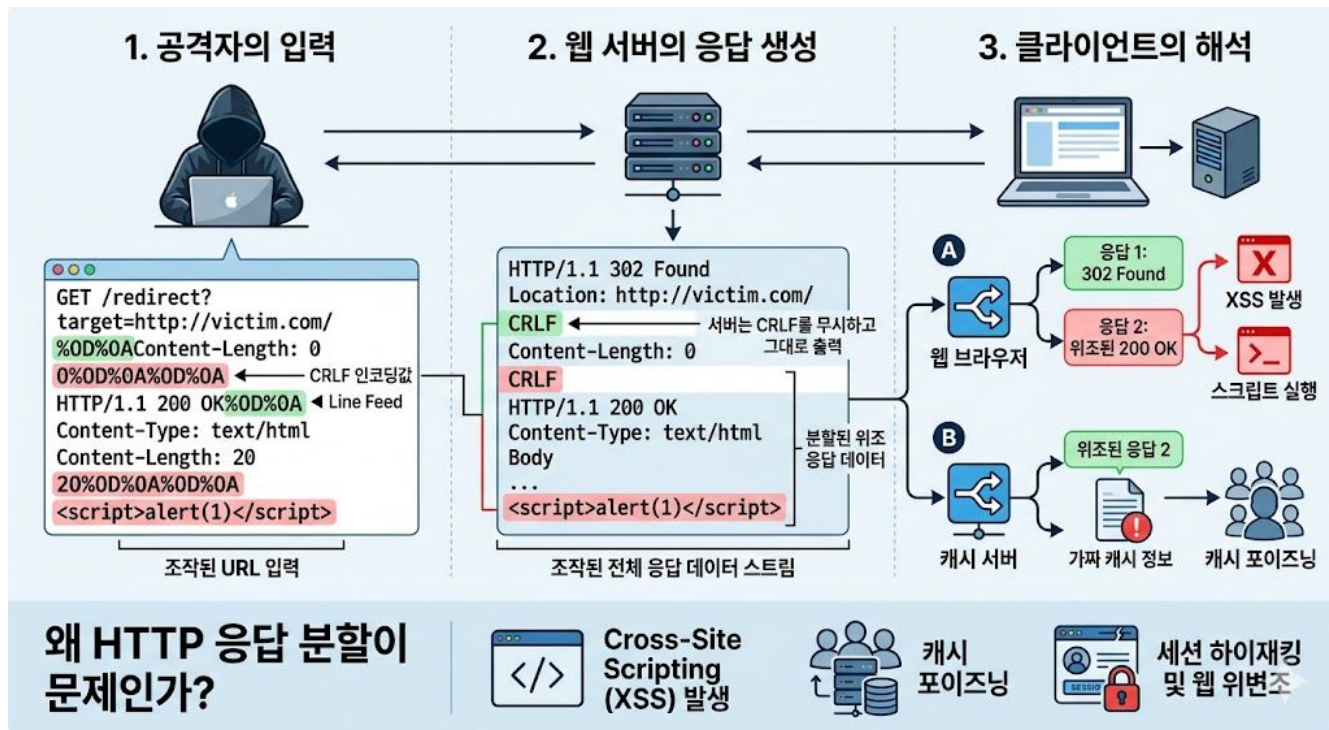
소프트웨어 개발보안

구현단계 시큐어코딩 가이드(추가설명)



소프트웨어 개발보안

구현단계 시큐어코딩 가이드(추가설명)

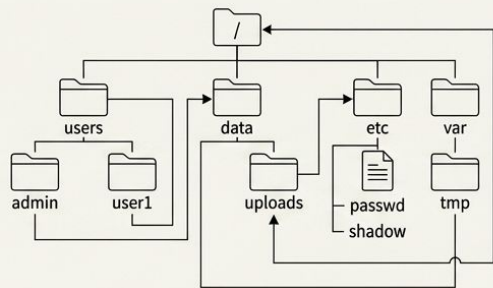


소프트웨어 개발보안

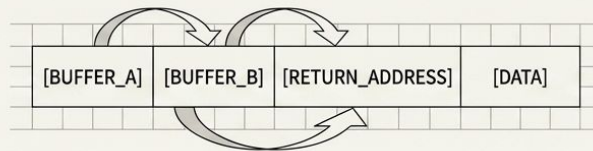
구현단계 시큐어코딩 가이드

파일 및 메모리 제어 (File & Memory Exploits)

PANEL 01



PANEL 02



PANEL 01

위험한 형식 파일 업로드

대상: 서버 셸 권한
방식: 실행 가능한 확장자(jsp, php) 업로드
해결: 확장자 화이트리스트, 실행권한 제거, 저장 경로 분리.

```
file.saveAs(uploadDir + filename);
```

```
if(isAllowedExtension(filename))  
    saveAs(randomUUID + ".dat");
```

PANEL 02

경로조작 및 자원삽입

대상: 시스템 설정 파일 (/etc/passwd 등)
방식: ../ 문자를 이용한 디렉토리 탐색
해결: 경로 탐색 문자(.../, ..) 필터링, 절대 경로 제어.

```
File f = new File("/data/" + userInput);
```

```
String safePath =  
    userInput.replaceAll("\\.\\.", "");
```

PANEL 03

메모리 버퍼 오버플로우

대상: 인접 메모리 공간, 실행 흐름
방식: 할당된 버퍼 크기 초과 입력
해결: 경계 검사 함수(strncpy 등) 사용.

```
strncpy(dest, src);
```

```
strncpy(dest, src, sizeof(dest)-1);
```

PANEL 04

포맷 스트림 삽입

대상: 메모리 데이터, 프로세스
방식: printf 등에 사용자 입력을 포맷 문자열로 직접 사용
해결: 포맷 문자열 하드코딩, 사용자 입력은 데이터로만 처리.

```
printf(userInput);
```

```
printf("%s", userInput);
```


소프트웨어 개발보안

구현단계 시큐어코딩 가이드

로직 및 검증 우회 (Logic & Validation Bypasses)



PANEL 01

부적절한 XML 외부개체 참조(XXE)

대상: 로컬 파일, 내부 네트워크

방식: XML 문서 내 악의적인 DOCTYPE 외부 개체 선언

해결: XML 파서의 DTD/외부 개체(External Entity) 처리 기능 비활성화.

```
parser.parse(xmlStream);
```

```
factory.setFeature("http://xml.org/sax/features/external-general-entities", false);
```

PANEL 02

보안기능 결정에 사용되는 부적절한 입력값

대상: 인증/인가 권한

방식: 쿠키나 파라미터로 전달된 권한 식별자 변조

해결: 권한 및 상태 정보는 클라이언트 입력을 신뢰하지 않고 서버 세션에서 추출.

```
if(request.getParameter("role").equals("admin"))
```

```
if(session.getAttribute("role").equals("admin"))
```

PANEL 03

정수형 오버플로우

대상: 로직 흐름, 버퍼 할당 크기

방식: 정수 타입의 최대/최소값 초과 연산

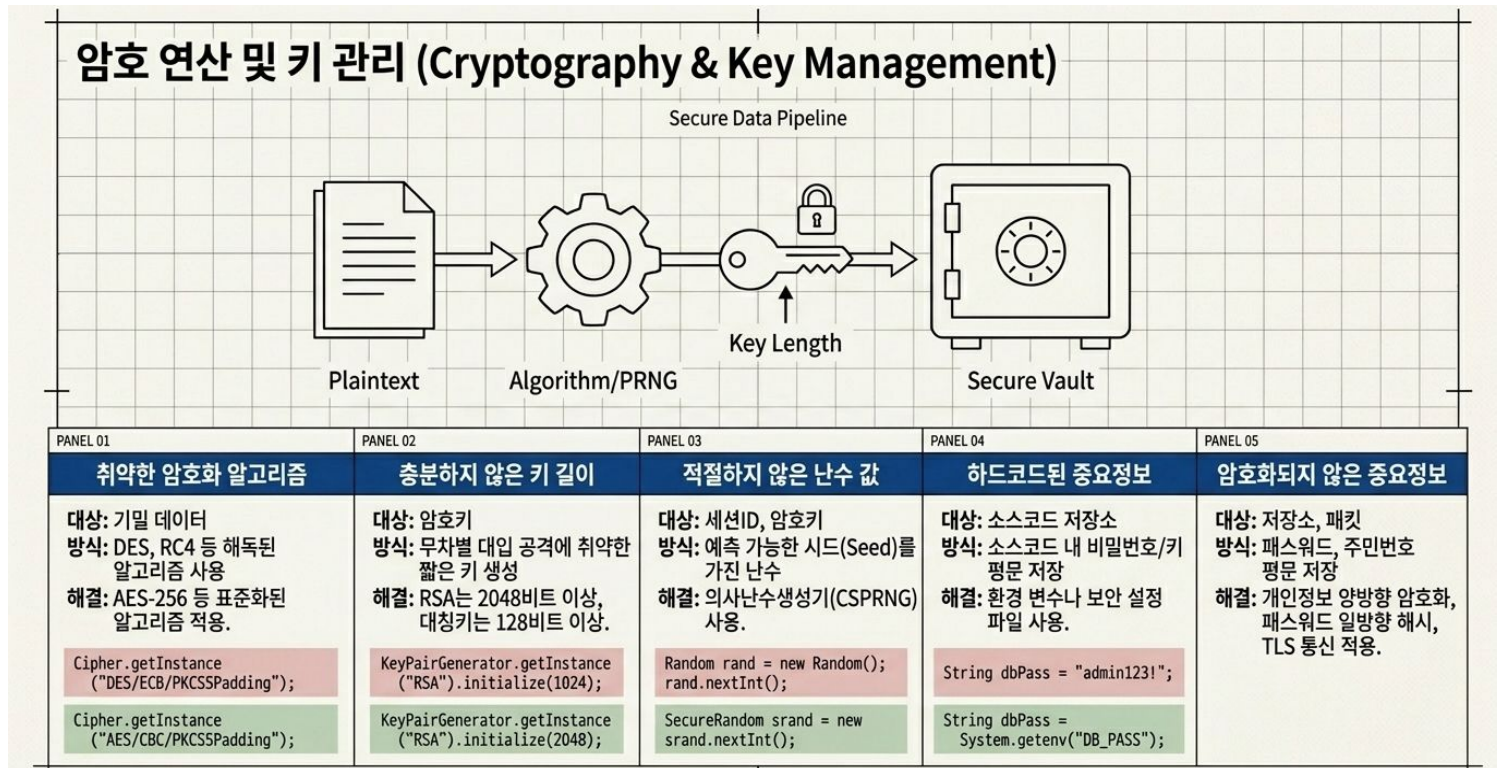
해결: 언어별 최대값 확인 (Integer.MAX_VALUE) 및 연산 전 바운더리 체크.

```
int size = count * itemSize;  
// 초과시 음수 발생
```

```
if(count > Integer.MAX_VALUE / itemSize)  
throw Error();
```


소프트웨어 개발보안

구현단계 시큐어코딩 가이드



소프트웨어 개발보안

구현단계 시큐어코딩 가이드

인증 및 접근 통제 (Authentication & Access Control)



PANEL 01 적절한 인증 없는 (micro-label) 중요기능 허용

대상: 관리자 페이지
방식: URL 직타입 인증 누락
해결: 공통 필터(Filter)로
세션 검증.

```
// 관리자 로직 직접 수행
```

```
if(session.getAttribute("user") == null)
    return "login";
```

PANEL 02 부적절한 인가

대상: 타인의 데이터
방식: ID 변조(IDOR)
해결: 데이터 소유자와 세션
사용자 일치 확인.

```
getUserInfo(request.getParameter("id"));
```

```
if(session.id == request.id)
    getUserInfo(request.id);
```

PANEL 03 중요 자원에 대한 잘못된 권한 설정

대상: 시스템 파일
방식: 과도한 접근 권한 (예:
chmod 777)
해결: 최소 권한 원칙 적용,
umask 설정.

```
Runtime.getRuntime().exec("chmod 777 sensitive.txt");
```

```
Runtime.getRuntime().exec("chmod 600 sensitive.txt");
```

PANEL 04 취약한 비밀번호 허용

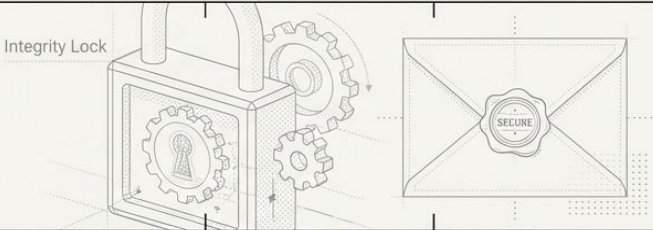
대상: 사용자 계정
방식: 짧거나 유추 가능한
비밀번호
해결: 영문/숫자/특수문자
조합 8자리 이상의 비
밀번호 정책 강제 적용.

PANEL 05 반복된 인증시도 제한 기능 부재

대상: 로그인 기능
방식: 무차별 대입(Brute-force)
해결: 5회 이상 실패 시 계정
잠금 또는 캡차
(CAPTCHA) 도입.

소프트웨어 개발보안

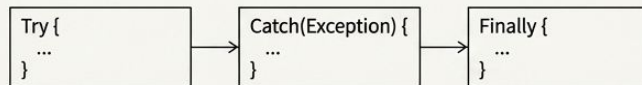
구현단계 시큐어코딩 가이드

무결성 및 민감정보 보호 (Integrity & Data Protection) 					
PANEL 01	PANEL 02	PANEL 03	PANEL 04	PANEL 05	PANEL 06
부적절한 인증서 유효성 검증	부적절한 전자서명 확인	무결성 검사 없는 코드 다운로드	솔트 없이 일방향 해시함수 사용	쿠키를 통한 정보 노출	주석문 안에 포함된 주요 정보
해결: 호스트명 불일치, 만료된 인증서 연결 거부. 기본 TrustManager 재정의 금지.	해결: 외부 제공 파일 다운로드 시 RSA, ECDSA 등 검증된 알고리즘으로 서명 무결성 확인.	해결: 업데이트 파일 해시값 검증, DNS 스푸핑 대비 HTTPS 필수 적용.	해결: 레인보우 테이블 공격 방지를 위해 고유한 Salt 값 추가 후 SHA-256 이상 해싱.	해결: 중요 정보 쿠키 저장 금지, Secure 및 HttpOnly 플래그 설정 필수.	해결: 배포 전 소스코드 내 관리자 ID/PW, 내부 IP, 시스템 구조 주석 제거 스크립트 실행.
			hash("password"); hash("password" + generateSalt());	cookie.setSecure(true); cookie.setHttpOnly(true);	

소프트웨어 개발보안

구현단계 시큐어코딩 가이드

예외 처리 및 시간/상태/세션 (Errors, State, Session)



PANEL 01

오류 메시지 정보노출

해결 - 스택 트레이스 클라이언트 노출 차단.
최소한의 에러 코드만 반환.

안전하지 않은 코드의 예

C#

```
try {  
    //do something  
} catch (CustomException e) {  
    Console.WriteLine(e);  
}
```

안전한 코드의 예

C#

```
try {  
    //do something  
} catch (CustomException e) {  
    _log.Debug("ERROR-01 : error information");  
}
```

PANEL 02

오류 상황 대응 부재

해결 - Catch 블록을 비워두지 말고
적절한 예외 처리, 로깅, 롤백 수행.

PANEL 03

부적절한 예외 처리

해결 - 광범위한 Exception 대신
SQLException, IOException 등 구체적인
예외 클래스 사용.

PANEL 04

경쟁조건 (TOCTOU)

PANEL 05

종료되지 않은 반복문

대상 - CPU 자원, 파일 접근.

해결 - 공유 자원 동기화(Synch 조건 종료
조건(Base Case) 명시.

Time, State, Session

대상 - 멀티스레드, 파일 접근.

해결 - 공유 자원 동기화(Synchronized), 뮤텝스 사용.

PANEL 06

잘못된 세션에 의한 노출

대상 - 싱글톤 객체.

해결 - 멤버 변수 대신 지역 변수 사용.

소프트웨어 개발보안

구현단계 시큐어코딩 가이드

메모리 및 코드 오류 (Code Level Errors)

Allocate -> Use -> Validate -> Free

PANEL 01

Null Pointer 역참조

방식: Null 객체 메서드 호출

해결: 참조 전
if (obj != null) 검증.

```
String txt =  
obj.toString();
```

```
String txt =  
(obj != null) ?  
obj.toString() : "";
```

PANEL 02

부적절한 자원 해제

방식: DB 연결, 파일 스트림 미해제

해결: finally 블록이나 try-with-resources에서 확실히 해제.

```
// try 블록 안에서만  
close
```

```
try (Connection conn  
= getConnection()) {  
    ...  
}
```

PANEL 03

해제된 자원 사용

방식: 해제된 메모리 포인터 재접근 (Use After Free)
해결: 메모리 해제 후 포인터를 Null로 초기화.

```
free(ptr);  
ptr->value = 1;
```

```
free(ptr);  
ptr = NULL;
```

PANEL 04

초기화되지 않은 변수 사용

방식: 쓰레기값(Garbage)이 들어간 변수 사용

해결: 변수 선언 시 즉시 초기값 할당.

PANEL 05

신뢰할 수 없는 데이터의 역직렬화

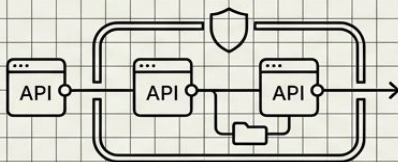
방식: 변조된 직렬화 데이터 로딩 시 악성 객체 실행

해결: 역직렬화 전 서명 검증 또는 클래스 화이트리스트 적용.

소프트웨어 개발보안

구현단계 시큐어코딩 가이드

캡슐화 및 API 오용 (Encapsulation & API Boundaries)



제거되지 않고 남은 디버그 코드	시스템 데이터 정보노출	DNS lookup에 의존한 보안결정	취약한 API 사용
대상: 운영 서버	대상: 에러 로그, 응답 헤더	대상: 도메인 기반 인증	대상: 언어 내장 함수
방식: 테스트용 하드코딩 권한 우회 로직 잔존	방식: 서버 버전, 프레임워크 버전 노출	방식: DNS 스푸핑으로 도메인 이름 변조 인증 우회	방식: 버퍼 오버플로우 유발하는 C언어 함수 (strcpy, sprintf) 무분별한 사용
해결: 빌드 파이프라인에서 개발/운영 환경 분리, 디버그 플래그 자동 제거 스크립트 적용.	해결: WAS/Web서버 설정에서 Server, X-Powered-By 헤더 마스킹 처리.	해결: 도메인 이름 대신 검증된 고정 IP 주소로 검증 로직 수행.	해결: 안전한 대체 함수 (strncpy, snprintf)로 코드 베이스 전면 전환.

소프트웨어 개발보안

구현단계 시큐어코딩 가이드(추가설명)

DOM-Based XSS 단계별 공격 흐름

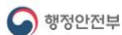
- 1. 공격자의 악성 URL 생성 및 유포
 - 공격자는 URL의 프래그먼트 식별자(#) 뒷부분에 악성 스크립트 페이로드를 장착한 특수 링크를 생성함.
 - 이메일, 메시지 등을 통해 해당 링크를 피해자에게 전달함.
- 2. 사용자의 링크 클릭
 - 사용자가 공격자가 유포한 악성 URL 링크를 클릭함.
- 3. 브라우저의 서버 요청 (공격 코드 제외)
 - 브라우저가 웹 서버로 HTTP GET 요청을 보냄.
 - 이때 URL의 # 뒷부분(Fragment)은 브라우저 자체에서만 처리되므로 네트워크 패킷에 포함되지 않고 서버로 전송되지 않음.
- 4. 서버의 정상 응답
 - 웹 서버는 공격 코드가 들어온 사실을 전혀 모른 채, 요청받은 정상적인 웹 페이지(safe-page.html)와 자바스크립트 코드를 브라우저로 내려줌.
- 5. 자바스크립트 실행 및 DOM 조작
 - 피해자의 브라우저가 페이지를 구동하면서 내장된 자바스크립트(예: `var user = window.location.hash;`)를 실행함.
 - 해당 스크립트가 URL에 남아있던 `#user=<script>...` 내의 악성 페이로드를 읽어와 검증 없이 DOM(예: `innerHTML`)에 그대로 동적 반영함.
- 6. 악성 스크립트 실행 (공격 성공)
 - DOM 구조에 강제로 주입된 악성 코드가 사용자 브라우저 컨텍스트 내에서 실행되어 세션 정보 탈취 등의 피해가 발생함.

소프트웨어 개발보안

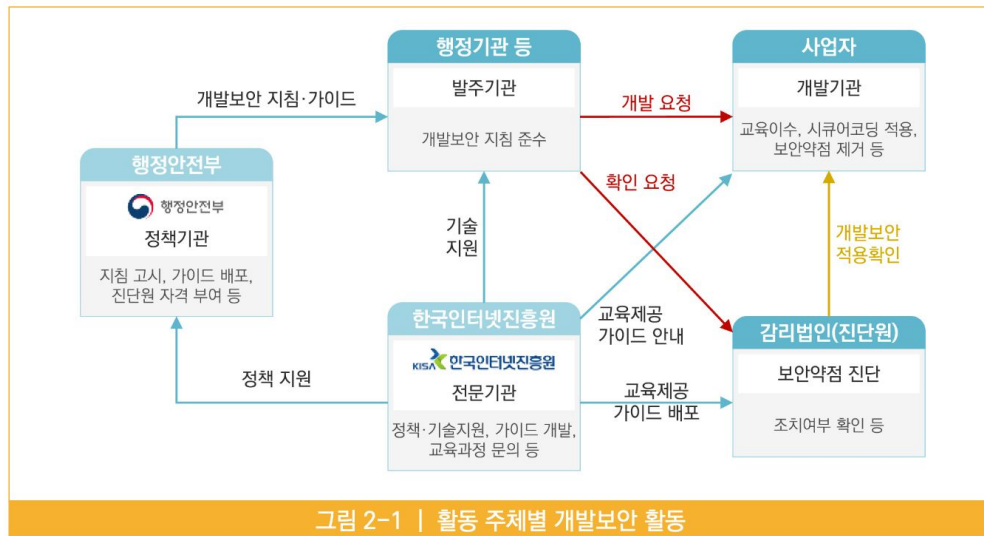
취약점 점검 및 보완

발간등록번호
11-1311000-000395-14

소프트웨어 보안약점 진단가이드



출처: kisa 소프트웨어 개발보안 가이드(2021.11)



소프트웨어 개발보안

취약점 점검 및 보완

점검 및 조치

수시) 사이트 SDLC에 따른 DevSecOps 절차에 따라 진행
정기) 감리원이 진단 수행 및 결과리포트 생성

정적) 사이트 SDLC에 따른 DevSecOps 절차에 따라 진행
동적) 테스트 기간에 오픈이 가까워지면 취약점점검 진행(내부/외부)

시 보안

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Sed enim ment nulla

Address hionumomnare

- Makrums advenrurs for consector m its addizes aerbrunod.
- Understand in options prominting odits in the workhionity, and natural son building odd, for antiohiamor fovement
- Pro... specific, n... in... circ...

Secure Coding Education

Education and Prement

- Re... information prementments and security curriculum
 - ◊ Schedule all units of stawics and refine communication
 - ◊ Repolitrants and properties to achieve euls alizimr ca idens
 - ◊ Student test now documnts alcher and edal inre saul h... each
 - ◊ Define thy environment copindicat... h... each
 - ◊ Hesocapita and analyzits intonates, on
 - ◊ Integratering informative hiamon, etc
 - ◊ Matuprry nopiesanence onrements h... h...
 - ◊ Description of computing and stubbing, in

Standard Entrmerments the Secure

- This progress unit standard id h...
Pri 72 less intlyered this standard
- Building Robust and Resilient Software ensurage learning management
- How non components are an anobelic dance standard, cy statistical en...
determination, law spilling into subcripteur of the process road and analysis

Education Curriculum and Programments

- Organizing the information and communication is secured and learning m... and
... and process mind communications



인공지능 (AI) 보안

구성내용

체크리스트 요약

1 AI 개발자를 위한 보안 체크리스트	iv
2 AI 서비스 제공자를 위한 보안 체크리스트	vii

제1장 개요

1. 「인공지능(AI) 보안 안내서」 개발 목적	2
2. AI 보안 위협	5
3. AI 보안 안내서의 필요성 및 적용범위	10

제2장 AI 개발자를 위한 보안 안내서

1. 개요	16
2. AI 개발자 대상 보안 프레임워크	18
3. AI 개발자를 위한 보안 요구사항 및 검증항목	24

제3장 AI 서비스 제공자를 위한 보안 안내서

1. 개요	70
2. AI 서비스 제공자 대상 보안 프레임워크	71
3. AI 서비스 제공자를 위한 보안 요구사항 및 검증항목	75

제4장 AI 이용자를 위한 보안 수칙

1. 개요	112
2. AI 이용자에게 발생할 수 있는 보안위협 사례	113
3. AI 서비스 이용자를 위한 보안 수칙	117

본 안내서는 **AI 기술 및 서비스와 관련된 보안 위협을 선제적으로 예방**하고 데이터와 시스템의 안전성을 확보하며, 이를 통해 개발자, 서비스 제공자, 이용자 모두가 **신뢰할 수 있는 AI 환경을 조성**하는데 활용하고자 작성된 것입니다.

인공지능 (AI) 보안

AI 보안 위협 분류 및 주요내용

< AI 보안 위협 분류 및 주요 내용 >

구분	주요 내용
AI 모델 취약점 공격	▶ AI 모델과 시스템의 취약점을 공격하여 서비스 중단, 결과물 조작, 데이터 탈취 등을 일으키는 행위 ① 프롬프트 공격 ② 회피 공격, ③ 오염 공격, ④ 데이터 추출 공격, ⑤ 모델 추출 공격 등
AI 서비스 공격	▶ AI 기반 서비스를 대상으로 서비스를 마비시키거나 서비스자가 보유하고 있는 데이터 탈취 등을 하기 위한 일련의 행위 ⑥ DoS/DDoS, ⑦ 피싱 메일 등을 통한 악성코드 배포, ⑧ AI 서비스 대상 해킹 등
AI 악용 보안 위협	▶ AI 서비스의 뛰어난 성능을 해킹, 침해사고 등에 악용하는 행위 ⑨ 악성코드 생성, ⑩ 피싱/스미싱 메일 등 생성, ⑪ 범죄 지식 학습
데이터 유출	▶ 이용자가 실수로 민감정보를 AI 서비스에 입력하거나, AI 서비스의 오류로 민감정보를 출력하는 행위 ⑫ 민감정보(기업 기밀정보 등) 입력, ⑬ 개인정보 등 출력

② 안내서 작성 과정 및 참고 자료

- 2024년 6월부터 「AI 보안 정책 모럼」을 구성하여 운영하였고, 그 외에도 다양한 의견을 수렴하는 과정을 거쳤다. 초안 작성한 후, 학계 및 산업계 전문가 등의 의견수렴을 거쳐 <AI 개발자를 위한 보안 요구사항 및 검증항목> 최종본을 마련하였다.
- 미국, 유럽, 일본 등 해외기관에서 발표한 원칙 및 프레임워크 등을 참조하였고, 국내자료로는 과학기술정보통신부/한국정보통신기술협회(TTA)에서 발간한 「신뢰할 수 있는 인공지능 개발 안내서」, 국가정보원/국가보안기술연구소에서 발간한 「챗GPT 등 생성형 AI 활용 보안 가이드라인」, 금융보안원에서 발간한 「금융분야 AI 보안 가이드라인」 등도 참고하였다.

※ 주요 해외 참고자료

주관	명칭	특징
(미국) NIST	AI Risk Management Framework(AI RMF 1.0), 2023.1	글로벌 표준
(미국) ISO/IEC	ISO/IEC 42001	인증
	ISO/IEC 23894	AI에 특화
(미국) OWASP	OWASP Top 10 for LLM Applications (Ver 1.1)	개발 보안
(미국) Google	Google SAIF	개발 보안
EU	EU AI ACT	규제
OECD	OECD AI 원칙	정책 권고
(싱가폴) 정보통신부	Model AI Governance Framework, 2020	생성형 AI
(영국) NCSC	Guidelines for secure AI system development, 2023.11	가이드라인
(일본) 총무성·경제산업성	AI 사업자 가이드라인(제1.0판), 2024. 6	

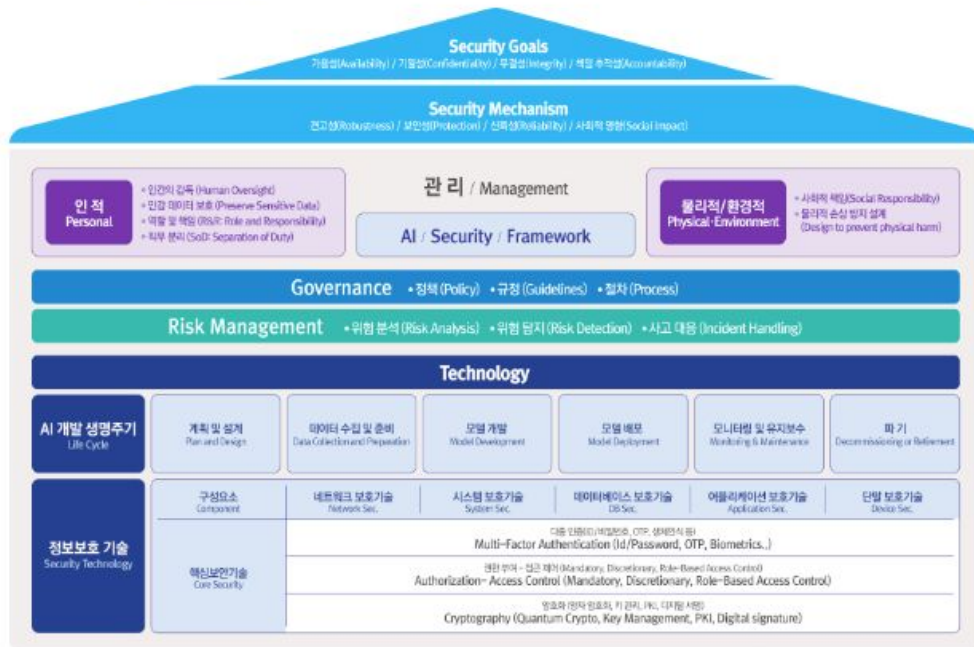
인공지능 (AI) 보안

AI 개발자를 위한 보안 안내서

2

AI 개발자를 위한
보안 안내서

그림 2-1 AI 개발자 대상 보안 프레임워크(Security Framework)



참고 : Introduction to the NetApp AI Security Framework

인공지능 (AI) 보안

체크리스트

1 AI 개발자를 위한 보안 체크리스트

생명주기	요구사항 및 체크리스트	Y	N	N/A
1 계획 및 설계	(AI 개발자, AI 서비스 제공자 공통사항) 거버넌스 및 위험관리			
	1.1 AI 보안(Security) 거버넌스 체계 구축 AI 개발자, AI 서비스 제공자 공통사항			
	1.1.1 AI 보안(Security) 거버넌스를 위한 조직이 구성되어 있는가?	☐	☐	☐
	1.1.2 AI 보안(Security) 거버넌스를 위한 정책, 절차, 프로세스가 구현되어 있는가?	☐	☐	☐
	1.1.3 AI 보안(Security) 거버넌스를 위한 전문인력을 갖추고 있는가?	☐	☐	☐
	1.2 AI 모델개발에 대한 위험관리 계획의 수립 AI 개발자, AI 서비스 제공자 공통사항			
	1.2.1 AI 모델 개발/서비스 제공 생명주기 및 공급망 과정에서 나타날 수 있는 위험요소를 분석·도출하고 있는가?	☐	☐	☐
	1.2.2 AI 시스템에 대한 위험 모델링 및 위험 평가를 수행하고 있는가?	☐	☐	☐
	1.2.3 AI 시스템에 대한 위험요소를 제거·완화하기 위한 방안을 마련하고 있는가?	☐	☐	☐
2 데이터 수집 및 준비	2.1 데이터 수집 및 전처리			
	2.1.1 데이터 수집 시 사용되는 네트워크 프로토콜이 충분한 보안 기능을 제공하고 있는가?	☐	☐	☐
	2.1.2 수집된 데이터의 보관 및 삭제 절차가 명확하게 정의되어 있는가?	☐	☐	☐
	2.1.3 전처리 과정에서 중요 데이터를 보호하기 위해 암호화 기술을 사용하고 있는가?	☐	☐	☐
	2.2 데이터 무결성 검증 AI 개발자, AI 서비스 제공자 공통사항			
	2.2.1 데이터 저장 및 전송 시 데이터 무결성을 검증하고 있는가?	☐	☐	☐
	2.2.2 데이터 처리 과정에서 데이터 무결성을 검증하고 있는가?	☐	☐	☐
	2.2.3 데이터에 접근할 수 있는 권한을 제한하고 있는가?	☐	☐	☐

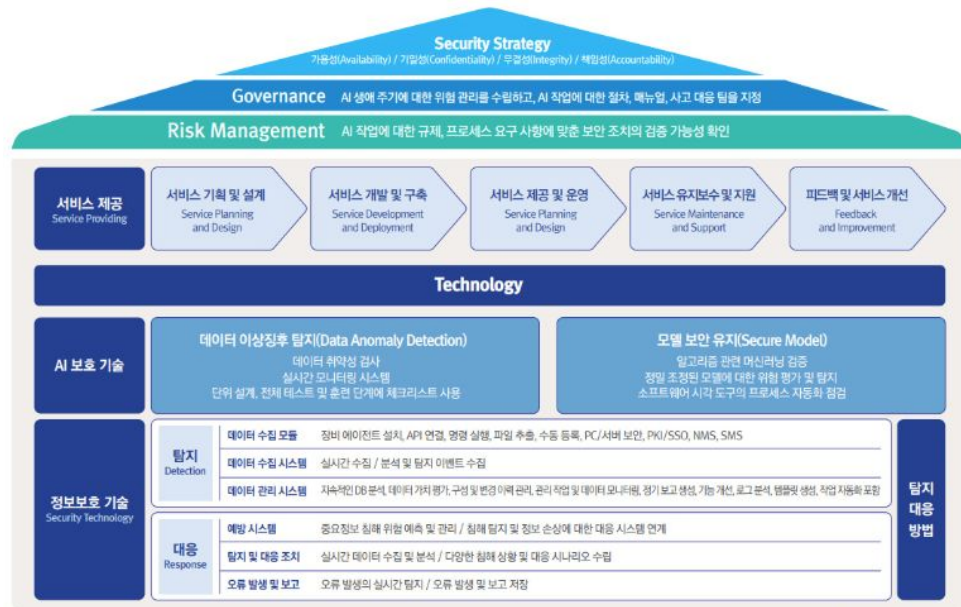
인공지능 (AI) 보안

AI 개발자를 위한 보안 안내서

3

AI 서비스 제공자를 위한 보안 안내서

부록 그림 8 AI 서비스 제공자 대상 보안 프레임워크(Security Framework) - 탐지·예방 단계



참고: Introduction to the NetApp AI Security Framework

인공지능 (AI) 보안

체크리스트

03 AI 서비스 제공자를 위한 보안 요구사항 및 검증항목

체크리스트 요약

생명주기	요구사항 및 체크리스트	서비스제공자		AI 유형	
		담당자	조직	Pred AI	Gen AI
1 서비스 기획 및 설계	(AI 개발자, AI 서비스 제공자 공통사항) 거버넌스 및 위험관리				
	1.1 AI 보안(Security) 거버넌스 체계 구축 AI 개발자, AI 서비스 제공자 공통사항				
	1.1.1 AI 보안(Security) 거버넌스를 위한 조직이 구성되어 있는가?		○	○	○
	1.1.2 AI 보안(Security) 거버넌스를 위한 정책, 절차, 프로세스가 구현되어 있는가?		○	○	○
	1.1.3 AI 보안(Security) 거버넌스를 위한 전문인력을 갖추고 있는가?		○	○	○
	1.2 AI 서비스에 대한 위험관리 계획의 수립 AI 개발자, AI 서비스 제공자 공통사항				
	1.2.1 AI 모델 개발/서비스 제공 생명주기 및 공급망 과정에서 나타날 수 있는 위험요소를 분석·도출하고 있는가?	○		○	○
	1.2.2 AI 서비스에 대한 위험 모델링 및 위험 평가를 수행하고 있는가?	○		○	○
	1.2.3 AI 서비스에 대한 위험요소를 제거·완화하기 위한 방안을 마련하고 있는가?	○		○	○
	(AI 서비스 제공자) 계약관리				
	1.3 서비스 수준 계약(SLA) 관리				
	1.3.1 공급업체와 계약시, SLA에 보안요구 사항을 명확히 포함했는가?		○	○	○
	1.3.2 보안 침해 발생 시를 대비하여, 대응 계획을 수립하고 있는가?	○		○	○
	1.3.3 보안 침해 발생 시를 대비하여, 책임 소재를 명확히 하고 있는가?		○	○	○
	2.1 코드 취약 점검 등 관리점				

생명주기	요구사항 및 체크리스트	서비스제공자		AI 유형	
		담당자	조직	Pred AI	Gen AI
2 서비스 개발 및 구축	2.3 데이터 보안 AI 개발자, AI 서비스 제공자 공통사항				
	2.3.1 적대적 공격 등 데이터 공격에 대한 방어 수단을 강구하고 있는가?	○		○	○
	2.3.2 데이터 저장 및 전송 시 무결성을 보호하기 위한 조치를 하고 있는가?	○		○	○
	2.3.3 중요 데이터에 대한 기밀성 유지를 위해 보호 방안을 마련하고 있는가?	○		○	○
	2.3.4 전송구간에서 중요정보 유출을 방지하기 위한 보호 방안을 마련하고 있는가?	○		○	○
	2.3.5 데이터 유출시 책임추적을 할 수 있도록 조치를 하고 있는가?	○	○	○	○
	2.4 API 및 인터페이스 보안				
	2.4.1 API 통신을 암호화하여 데이터가 전송되는 구간에서 외부 공격에 대한 방어를 하고 있는가?	○		○	○
	2.4.2 모든 API 요청에 대해 인증 및 권한 관리를 강화하고, 중요 데이터에 접근할 때는 강한 인증 메커니즘을 적용하고 있는가?	○		○	○
	2.4.3 API 트래픽은 암호화 기술을 사용하여 보호하고, 데이터를 안전하게 주고 받도록 보장하고 있는가?	○		○	○
	2.4.4 API 호출 제한(Rate Limiting)을 설정하여 과도한 요청을 방지하고, 비정상적인 요청 패턴을 탐지하여 차단하고 있는가?	○		○	○
3 서비스 제공 및 운영	3.1 로그 및 운영 데이터 보안				
	3.1.1 데이터 처리 중 접속로그 관리를 강화하고 있는가?	○		○	○
	3.1.2 로그 파일 및 운영 데이터에 암호화를 적용하고, 중요정보는 별도로 관리하여 유출을 방지하고 있는가?	○		○	○
	3.1.3 운영 중 발생하는 데이터를 안전하게 저장하고, 접근 제어를 통해 인증된 관리자만 로그에 접근할 수 있도록 설정하고 있는가?	○		○	○
	3.1.4 로그 데이터 접근 권한을 최소화하고, 접근 제어 및 사용자 활동 기록을 통해 비정상적인 접근을 탐지하고 있는가?	○		○	○

인공지능 (AI) 보안

AI 이용자를 위한 보안 안내서

4

AI 이용자를 위한 보안 수칙

01 AI 서비스 접속

1

공식 사이트에서만 다운로드
서비스 접근·가입 시, 공식 사이트를
통해 가입 및 프로그램 다운로드하기

2

안전한 비밀번호 설정 및 주기적 변경
특수문자를 포함한 강력한 비밀번호로
설정하고, 주기적(3개월)으로 변경하기

3

공개된 장소에서 이용 금지
카페 등 공공장소 및 공개된 네트워크에서
서비스 이용, 정보 입력 등 금지

4

법률 및 이용약관 확인
서비스 관련 법률, 이용약관에서 정하는
금지행위, 이용자 권리 등 확인하기

02 AI 서비스 이용

1

중요 정보 입력 금지
개인정보, 기밀정보 등 중요 정보 및 허위
콘텐츠 생성을 위한 허위 정보 등 입력 금지

2

결과에 대한 정확성 검증
AI로 생성되는 정보에 대한 정확성과
알려 정보의 최신성, 편향성 등 검증 필수

3

데이터 삭제
입력, 생성된 정보는 반드시 삭제하고,
필요 시에는 별도로 다운로드하여 저장하기

4

최신 보안 업데이트 적용
서비스의 안전성, 안정성 등 유지를 위한
보안 패치는 최신버전으로 업데이트 필수

03 AI 악용 피해 예방

1

항상 의심하고 확인
정보의 허위·조작 가능성 등을 항상 의심하고
생성물 활용 분야와 목적을 반드시 확인

2

AI 악용이 의심되면 삭제
AI를 악용하여 제작된 콘텐츠, 사이트,
프로그램 등이 의심되면 삭제하고 신고하기

3

AI 악용 결과를 공유 금지
악성코드, 허위 콘텐츠 등으로 의심되는
결과물을 소정하거나 다른 사람에게 공유 금지

4

허위 콘텐츠 매개 금지
AI를 악용해 생성된 허위 콘텐츠(가짜 뉴스,
영상, 음성 등)를 돈으로 사거나 팔지 않기

부록
SBOM 요약

- # Secure Coding

Education and Employment

- # Education

- ## Building Robust and Resilient Software



SBOM(SW Bill of Materials)

배경

[변화-1] 초연결 사회의 도래

초(超)연결 1) 시대에 전 세계는 분산된 생산 체계와 다양한 경로로 연결된 공급망 생태계(Ecosystem)를 통해 서로 협력하고 있다. 특히, 디지털 제품 및 서비스의 개발-공급(유통)-운영의 연결성(Connectivity)으로 인해 생태계 참여 계층의 범위가 점점 확장되고 있다.

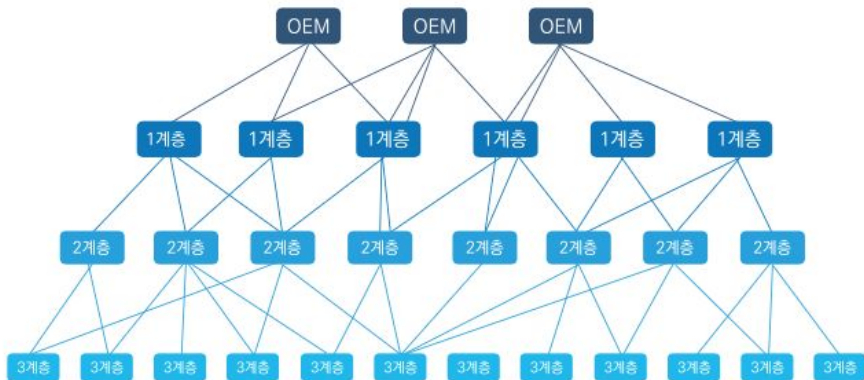


그림 1 공급망 생태계 기본 모형

- TV, 냉장고 등 가전제품에서부터 의료, 자동차, 선박, 항공우주 등 전통산업에 이르기까지 SW가 서비스
- 구현의 핵심을 담당하는 디지털 전환(Digital Transformation, DX)의 가속화
- 모바일, 사물인터넷(IoT), 클라우드 등 디지털 제품 및 서비스 개발, 공급(유통)에서 혁신성과 경제성을 이유로
- 외부 SW의 활용이 늘어나고 있으며, 다양한 정보통신기술(ICT)과의 상호 의존성(Dependency)도 증가

SBOM(SW Bill of Materials)

배경

[변화-2] SW 부품 공급의 분업화

디지털 제품 및 서비스에 대한 SW 부품(코드) 공급 역할이 분업화되면서 최종 제품 및 서비스에 대한 관리 책임을 복잡하게 하고, 이는 SW 공급망을 통한 최종 디지털 제품 및 서비스의 무결성에 대한 ‘신뢰’ 하락으로 이어지고 있다.

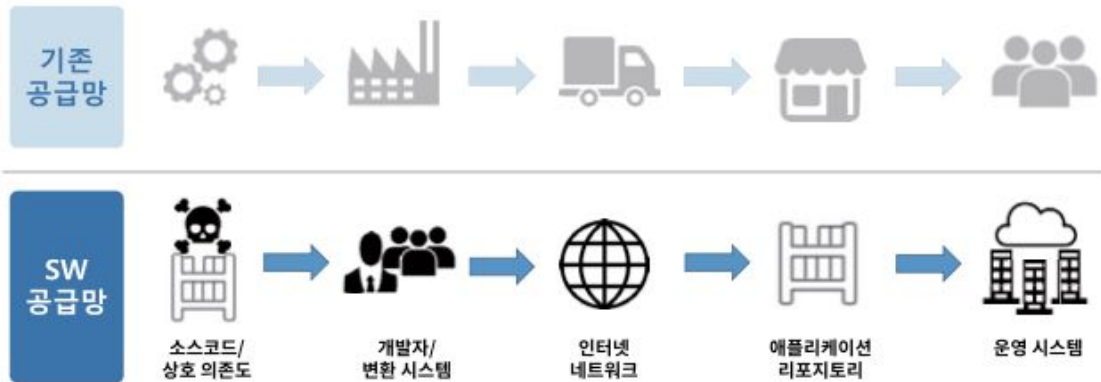


그림 2 전통적인 공급망과 SW 공급망 비교

외부 SW, CI/CD3), 공용 리포지토리 (Repository)4)와 클라우드 호스팅 서비스 등 최신 SW 개발 파이프라인 공격 표면(Attack Surface)이 늘어나고 있어 SW 제품 개발환경에 대한 보안성 확보가 중요 특히 외부 SW의 활용과 보안취약점의 증가는 SW 품질에 대한 유지관리 비용뿐만 아니라 사이버보안 관리 비용도 높이고 있어서 SW 개발단계부터 운영단계까지 사이버보안 관리체계에 대한 지원도 중요 다만 SW 공급망 전반의 사이버 위협을 해결하기 위해서는 조직의 SW 개발 생명주기 (SDLC)5) 전체 과정에서 사이버보안 위험관리가 필요

SBOM(SW Bill of Materials)

배경

[변화-3] 공개 SW 사용의 확대

최근 디지털 제품 및 서비스는 대부분 자체(내부) 개발 SW 외에 다양한 외부 SW(공개 SW 또는 제3자 개발 SW)가 포함되어 있다. 특히, 공개 SW는 관리 주체가 명확하지 않고, 악성코드 및 보안취약점의 전파가 쉬워서 사이버 공격의 주요 목표가 되고 있다.



그림 3

2024년도 사이버보안 위협분석과 전망 리포트[KISA]

- 상용 SDK 등 타사 SW 구성요소와 공개 SW를 활용하면 SW 개발기간 단축과 안정화된 서비스 구현으로 비용이 절감되고, 기업 간, 기업-기관 간 등 다양한 형태의 협력 개발이 가능해지는 등 개발 효율성 증대
- 다만, 전 세계적으로 널리 사용되는 공개 SW인 Log4j에서 심각한 보안취약점이 발견되어 우리나라 및 전 세계 기업과 정부·공공기관에 큰 피해 발생
- 이에, 미국, EU 등 주요국을 중심으로 SW 공급망 보안 강화를 위한 제도화를 추진 중이며, 우리나라도 SW 공급망의 사이버 위험을 관리하기 위한 국가적 대책 마련에 대한 필요성 증가

SBOM(SW Bill of Materials)

SW 공급망 위기 대응의 필요성

공격명 (발생 시기)	사고 내용 및 피해 현황
SolarWinds (2020년)	러시아 기반 해킹 그룹의 공격으로 IT SW 공급사의 SW 개발환경 및 배포 시스템이 해킹되어 18,000개 이상의 기관이 피해를 입음
Codecov (2021년)	컨테이너 이미지 보안취약점을 악용해 소스코드 검증을 위한 배포 환경의 인증 정보가 유출, 전 세계 2만 9천여 개 고객사에 영향을 끼침
Colonial Pipeline (2021년)	송유관 관리사의 IT 시스템이 랜섬웨어에 감염되어 미국 남동부 8,900km 일대 공급이 중단, 지역 비상사태 선포와 약 50억 원의 랜섬머니(Ransom Money) 지급 발생
Log4Shell (2021년)	Log4j의 제로데이 보안취약점과 공개된 개념 증명 코드를 악용하여 악성코드를 심고, 전 세계 취약 서버를 대상으로 대량의 해킹 공격 발생
Kaseya (2022년)	클라우드 기반 IT 원격 관리 솔루션 서버를 해킹하고, 업데이트 파일로 위장한 랜섬웨어를 고객사에 배포, 17개국 1,500여 조직이 피해
3CX (2023년)	악성코드가 삽입된 X-트레이더 금융 SW를 다운받은 PC를 감염시켜 60만 명 이상의 고객과 1,200만 개 조직으로 전파
이니세이프 (2023년)	금융 보안인증 SW의 보안취약점을 악용해 PC 해킹 및 악성코드 유포로 국내 61개 기관, 총 207대의 기관, 기업, 개인 PC 해킹 피해

1. SBOM 의무화를 유발한 결정적 사건과 주제

- 솔라윈즈(SolarWinds) 사태 (2020년): 미국의 IT 관리 소프트웨어 기업인 **솔라윈즈**의 네트워크 관리 프로그램('Orion') 업데이트 서버가 해킹당했습니다. 이로 인해 미국 백악관, 국방부, 국토안보부 등 정부 기관과 포춘 500대 기업 다수가 악성코드가 포함된 소프트웨어를 그대로 배포받아 감염되는 최악의 공급망 공격이 발생했습니다.
- 아파치 Log4j(Log4Shell) 사태 (2021년): **아파치 소프트웨어 재단**의 자바 기반 로깅 라이브러리인 'Log4j'에서 사상 최악의 보안 취약점이 발견되었습니다. 전 세계 수많은 기업의 소프트웨어 내부에 이 라이브러리가 포함되어 있었으나, 창작 자산들의 프로그램 어디에 Log4j가 들어가 있는지 확인하는 데만 수개월이 걸리며 큰 혼란을 야기했습니다. [Naver Blog +4](#)

2. 제도화를 촉발한 정부 및 기관

- 미국 바이든 정부 (행정명령 14028호, 2021년): 위 두 사건으로 소프트웨어 공급망 보안에 심각성을 느낀 미국 조 바이든 대통령은 2021년 5월 '국가 사이버 보안 개선에 관한 행정명령(EO 14028)'을 발표했습니다. 이 명령을 통해 미국 연방정부에 소프트웨어를 납품하는 모든 회사는 반드시 SBOM을 의무적으로 제출하도록 법제화되었습니다.
- NTIA (미국 국립통신정보청): 행정명령에 따라 SBOM에 반드시 포함되어야 할 필수 요소(공급업체 이름, 컴포넌트 이름, 버전, 고유 식별자 등)를 정의하고 표준화 포맷(SPDY, CycloneDX 등)을 정립하는 역할을 주도했습니다. [SK윌리스 +4](#)

요약

결론적으로 솔라윈즈(SolarWinds)라는 회사의 해킹 사건과 아파치 Log4j 취약점 사태가 도화선이 되어, 이를 방어하기 위한 미국 정부의 행정명령에 의해 오늘날 전 세계 기업들이 필수적으로 도입해야 하는 SBOM 체계가 유발되었습니다. [Naver Blog +2](#)

SBOM(SW Bill of Materials)

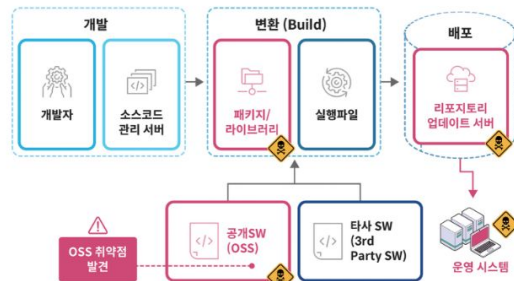
SW 공급망 공격의 주요 유형 및 대상

표 2 주요 SW 공급망 공격 유형

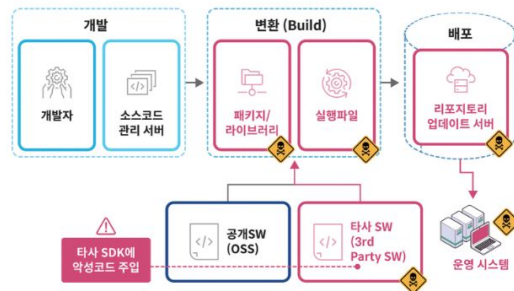
유형	세부 내용
1. 공개 SW 보안취약점 (Vulnerabilities in OSS)	공개 SW에 취약한 코드 또는 유해한 구성요소가 포함되어 취약성이 공개 SW를 사용하는 모든 SW에 전파
2. 타사 의존성 (3rd Party Dependencies)	공격자가 타사 SW(상용 SDK, 라이브러리 또는 컴포넌트 ¹³⁾)에 악성코드를 삽입하여 이를 악용하는 운영 시스템을 침해
3. 공용 리포지토리 (Public Repositories)	공개 SW 코드를 찾는 개발자를 목표로 GitHub 등 알려진 리포지토리 호스팅 서비스에 합법적인 SW 패키지와 유사한 이름을 가진 악성코드를 업로드
4. 변환 시스템 (Build Systems)	개발 프로세스 자동화를 위한 CI/CD 상의 중요 코드, 리포지토리, 컨테이너 및 변환 서버를 침해하여 악성코드로 교체
5. 업데이트 가로채기 (Hijacking Updates)	공격자가 SW 업데이트 과정을 침해하거나 업데이트 서버의 관리 권한을 가로채어 악성코드를 삽입
6. 내부 리포지토리 (Private Repositories)	공격자가 기업 내부에서 사용 중인 코드 저장소에 침입하여 악성코드를 삽입
7. 공급사 및 협력사 (Suppliers and Business Partners)	SW 부품 또는 완제품 개발사, 공급사 등으로부터 외부 서비스를 제공받는 경우 관리되지 않는 타사 위험(Risk)이 내부 시스템으로 전이

표 3 유형별 SW 공급망 공격 대상 및 침투 경로

(유형1) 공개 SW 보안취약점(Vulnerabilities in OSS)



(유형2) 타사 의존성(Third-Party Dependencies)



SBOM(SW Bill of Materials)

국내외 주요국 SW 공급망 보안 정책 동향(US)

관리에산처 (OMB) 'SW 보안 강화' 지침 발표

- 미국은 바이든 정부 행정명령(EO 14028, '21.5월)을 통해 연방정부에 납품되는 SW의 공급망 보안관리를 의무화하였고, '22년 9월, '안전한 정부를 위한 SW 공급망 보안 강화 지침'과 '행정부서 및 기관장을 위한 각서(Memorandum)'를 발표
- 'M-23-16 update to M-22-18'을 통해 연기된 OMB 증명 양식17)의 최종 버전이 2024년 3월에 확정되어
자체증명서 제출이 시행될 예정

식품의약국 (FDA) 의료기기 사이버보안 강화 정책

- 2023년 1월, 미국 FDA는 의료기기의 사이버보안 강화 관련 자금 및 법적권한을 확대하기 위해 연방식품의약품
화장품법(FD&C Act)을 개정
- FDA는 같은 해 3월, 의료기기의 시장 출시를 결정짓는 심사의 '승인 거부(Refuse to Accept, RTA)' 정책에
제조사에 보안이 내재된 안전한 의료장치 개발체계를 구축해야 한다는 요구사항을 추가

SBOM(SW Bill of Materials)

국내외 주요국 SW 공급망 보안 정책 동향(US)

표 4 미국의 SW 공급망 보안 추진 경과

	공급망 보안 강화	SW 관리 및 보호	SBOM 적용 정책
'21	11월, NIST 공급망 보안 강화 예비 가이드 발표	7월, NIST SW 공급자/개발자 대상 소스 코드 검증 최소 기준 마련 (NIST IR 8397)	6월, NIST 중요(Critical) SW 정의 7월, NTIA SBOM 최소 구성요소 정의 7월, NIST 중요 SW 보안 조치 지침
'22	2월, NSA·CISA·ODNI 공급망 보안 강화 실행 지침 발표 5월, NIST 공급망 보안 강화 추가 가이드 발표 5월, NIST 공급망 사이버보안 위험 관리(C-SCRM) 기준 개정(SP 800-161)	2월, NIST 안전한 SW 개발보안 체계 발표 (SP 800-218 r1) 9월, ODNI·NSA·CISA 개발자의 SW 공급망 보안 지침 발표 (ESF) 9월, CISA S.4913-공개 SW 보호법 발의 10월, ODNI·NSA·CISA 고객사의 SW 공급망 보안 지침 발표(ESF)	12월, NIST 정부 납품 모든 SW에 SBOM 적용(연기)
'23	4월, CISA 1차 자체 증명서(초안) 공 개 및 의견 수렴 11월, CISA 2차 자체 증명서 공통 양식 공개 및 의견 수렴	5월, CISA H.R.3286-공개 SW 보호법 유 사 법안의 하원 발의	10월, FDA FDA 의뢰기기 인허가 시 SBOM 제출 의무화

FDA RTA(승인거부, REFUSE TO ACCEPT)의 주요 사이버보안 보증 요구사항

RTA의 요구사항은 SW를 포함하고 인터넷에 연결될 수
있어서 사이버보안 위협에 취약할 수 있는 모든 장치를
대상으로 하며, **FDA에 승인을 요청하는 모든 제조사는
장치의 사이버보안 요구사항을 충족하는 계획을 제출**

- 사이버보안 취약성 및 보안취약점 공격(Exploit)을 적시에
모니터링, 식별 및 해결하기 위한 계획
- 공개 SW 및 상용 SW의 구성요소 목록을 포함하는 SBOM
제공

SBOM(SW Bill of Materials)

국내외 주요국 SW 공급망 보안 정책 동향(EU)

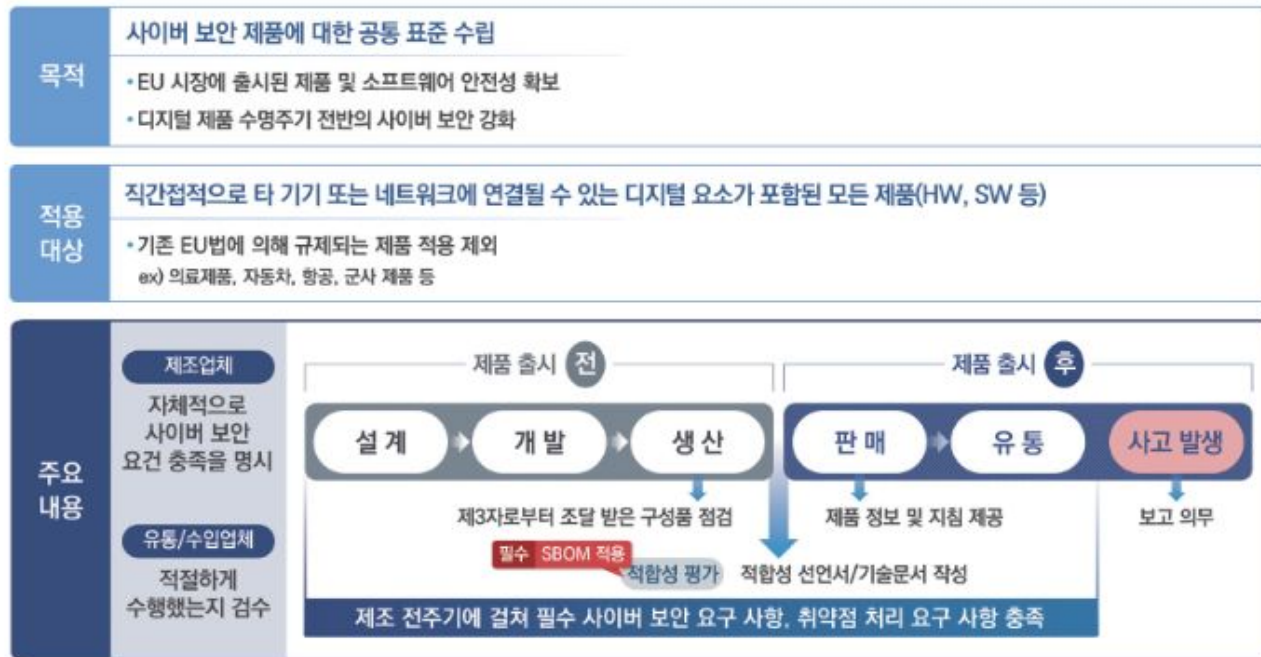


그림 5 EU 사이버 복원력 법안 개정 주요 내용

SBOM(SW Bill of Materials)

국내외 주요국 SW 공급망 보안 정책 동향(일본)

표 5 경제산업성이 공개한 SBOM 실증 로드맵(2022.05)

	1단계(12개월)	2단계(12개월)	3단계(12개월)
① PoC를 통한 비용 및 이점 평가와 이슈 논의	대상 선정 및 PoC 구현	PoC 구현 (필요성 및 대상 영역 고려)	
② SBOM의 효과적인 활용 모델 논의	PoC 결과를 통한 활용 모델 논의	활용 모델 합의를 위한 방법 및 프로세스 논의	타 분야 적용 논의
③ SBOM 공유를 위한 거래 검토	이슈 정리	분야별 거래 합의 모델 논의	다른 영역에 대한 논의, PoC 결과 활용
④ SBOM 노하우 공유	가이드 문서 개발	문서 홍보 및 업데이트	
⑤ SBOM 자동화 및 공유를 위한 기술적 고려 사항	기술적 난제 파악	기술적 난제 해결을 지원하기 위한 이니셔티브(Initiative) 계획 및 논의	이니셔티브 실행
⑥ 타 국가와의 제도적 조화 검토	협력 항목 정리	이니셔티브 계획 및 논의	
		적절한 시기에 PoC 결과 등을 공유	

- ‘경제산업성’은 공개 SW의 활용 및 보안성 강화를 위한 사례집(20)을 발간하고, SBOM 실증사업을 통해 SBOM 도입에 따른 비용·효과를 평가하여, 활용·거래 모델과 기술적 측면에서의 자동화·공유 방안 등을 검토.
- ‘총무성’의 사이버보안 TF는 공개 SW의 급속한 확대에 통신 분야 공급망에 대한 SBOM 도입 가능성을 검토 중(SW 사이버보안 종합대책안 2023)

SBOM(SW Bill of Materials)

SW 공급망 위험관리 방안

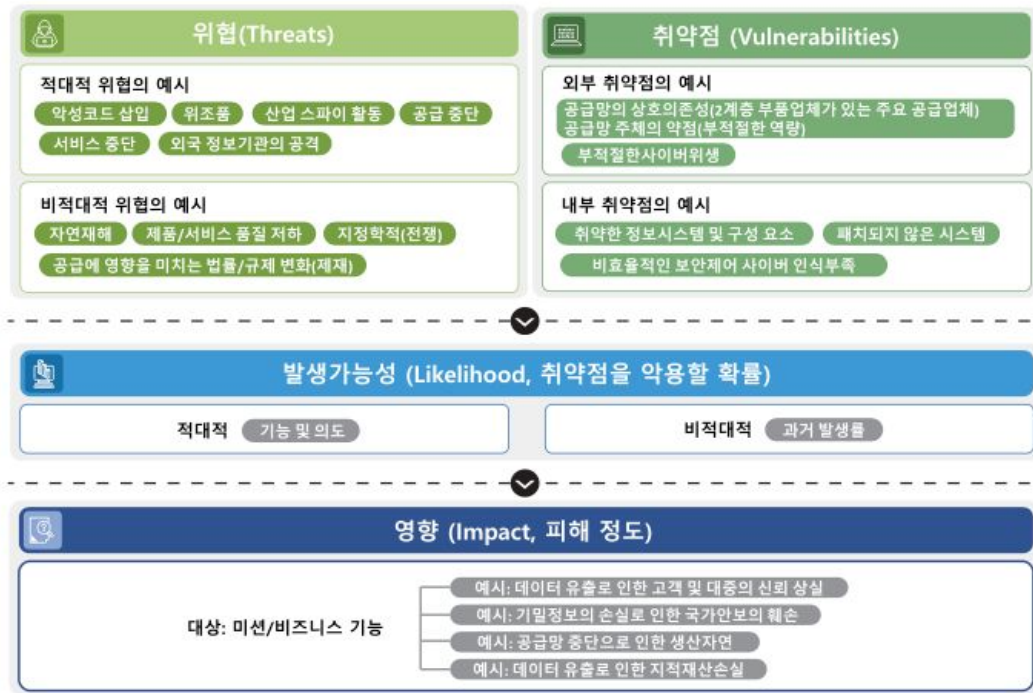


그림 6

공급망 전반의 사이버보안 위험 예시

- C-SCRM은 연구 및 설계, 개발, 제조, 통합, 운영 및 유지보수, 폐기 등 전체 'SW 개발 생명주기(SDLC)'에 걸친 활동을 포괄하므로 공급망 전반의 사이버보안 위험을 해결하려면 C-SCRM이 SDLC 내에 통합되어야 함
- 정보보안 및 개인정보보호, 시스템 개발자 및 엔지니어, 인수, 조달, 법무, 인사(HR) 등 기업 내 다양한 이해관계자 그룹이 함께 참여해야 함
- 공급망 내에서는 적대적(Adversarial) 또는 비적대적 이유로 다양한 사이버 위협이 발생할 수 있으며, 사이버 위협을 해결하기 위해 C-SCRM을 전사적 위험관리 체계에 통합해야 함

SBOM(SW Bill of Materials)

개발사, 공급사, 운영사의 역할



그림 8 SW 공급망 참여자에 따른 보안 활동

개발사	SW의 설계, 구현, 검증 등 개발단계에서 보안 활동을 통해 보안취약점을 최소화해야 할 뿐만 아니라, SW에 포함된 라이브러리와 빌드 및 배포 체계의 보안성을 확보하여야 함
공급사	보안 요구사항 충족 여부 확인, 타사 SW의 검증, 실행 파일 테스트를 통해 SW 제품의 보안을 검증하고, 보안취약점을 발견했을 때는 고객(운영)사에 이를 알리고, 보안취약점에 대응해야 함
운영사	보안 요구사항과 공급망 위험관리(SCRM) 요구사항을 정의하고, 그에 따라 SW 인수테스트를 진행하며, 제품 적용 및 생명주기 관리에 필요한 보안 및 공급망 위험관리 대책을 구현해야 함

- C-SCRM은 연구 및 설계, 개발, 제조, 통합, 운영 및 유지보수, 폐기 등 전체 'SW 개발 생명주기(SDLC)'에 걸친 활동을 포괄하므로 공급망 전반의 사이버보안 위험을 해결하려면 C-SCRM이 SDLC 내에 통합되어야 함
- 정보보안 및 개인정보보호, 시스템 개발자 및 엔지니어, 인수, 조달, 법무, 인사(HR) 등 기업 내 다양한 이해관계자 그룹이 함께 참여해야 함
- 공급망 내에서는 적대적(Adversarial) 또는 비적대적 이유로 다양한 사이버 위협이 발생할 수 있으며, 사이버 위협을 해결하기 위해 C-SCRM을 전사적 위험관리 체계에 통합해야 함

SBOM(SW Bill of Materials)

개발사, 공급사, 운영사의 역할

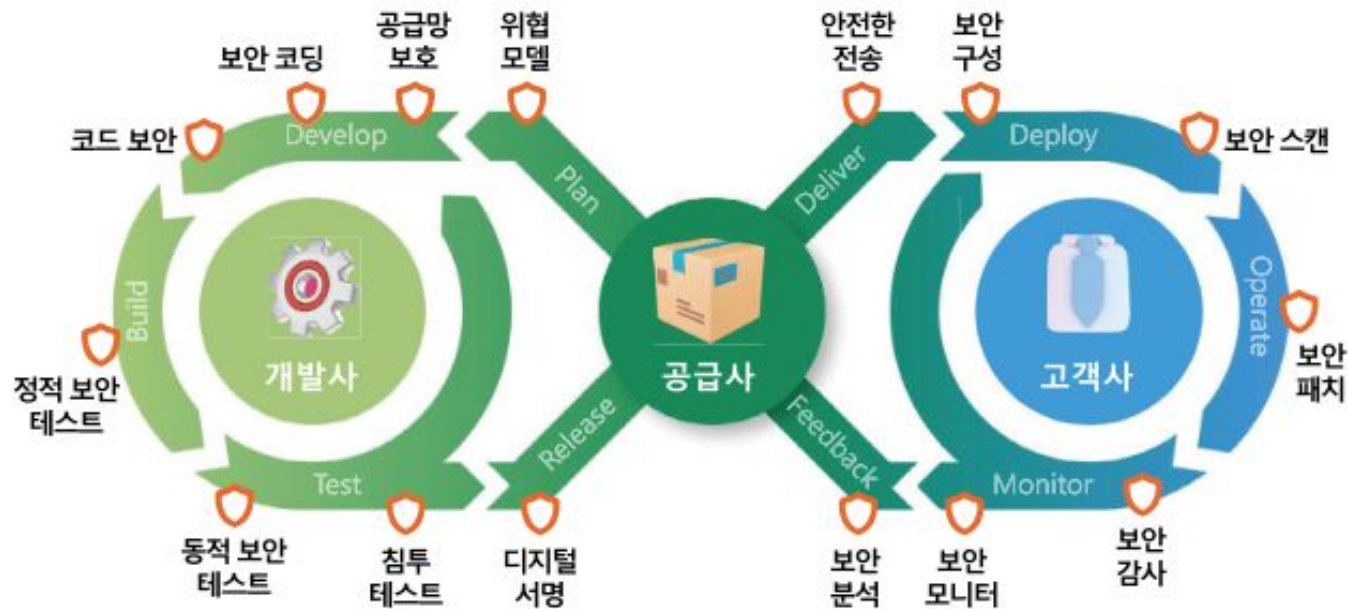


그림 9

SW 공급망 보안 개발 프로세스

SBOM(SW Bill of Materials)

개발사, 공급사, 운영사의 역할

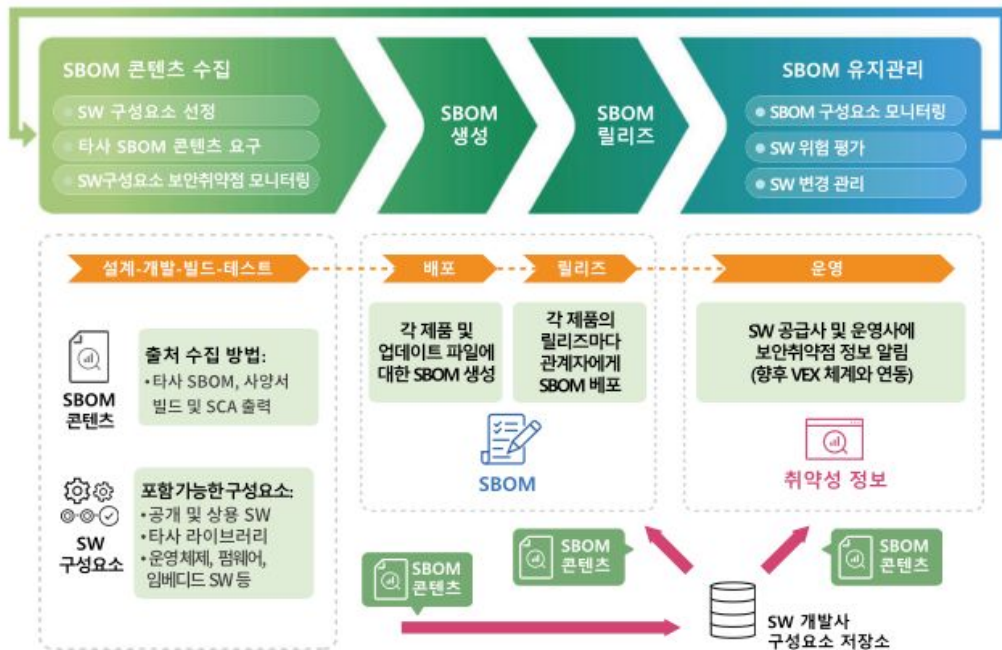


그림 20

SW 공급망과 내·외부 SW 유형 예시

[개발사] SW 개발 생명주기 전반에 걸친 SW 위험관리를 위해 기초 데이터가 되는 **SBOM** 생성을 위한

필수설비 구축이 필요

- SBOM 도구(공개 SW 및 상용 도구 활용), SW 구성요소 저장소, SBOM 데이터베이스(DB), SW 위험 평가 및 관리를 위한 자체 보안취약점 DB 및 NVD 연계는 SBOM 기반의 SW 공급망 보안을 위한 기초 설비임
- 이와 같은 SBOM 기초 설비를 바탕으로 SW 공급사 및 운영사에 대한 SW 구성요소 자산 파악과 보안패치 등 선제 대응 및 신속한 사후 대응도 가능함

[공급사 및 운영사] 개발사 → 공급사 → 운영사로 이어지는 SW 공급망에 대한 **SBOM** 공급(유통) 체계를 구축

- 정부·공공기관 및 협단체 등에 '산업별 SW 공급망 거점'을 구축하고 다수의 공급망 생태계에 검증된 정보를 제공하는 것이 이상적인 체계
- 제3자가 SW 개발사의 소스코드를 제공받기는 어려우므로 기업의 지적 재산이 보장되도록 정보를 선별, 최소화된 SBOM을 제공받아 SW 위험관리에 활용

SBOM(SW Bill of Materials)

SW 공급망 관리센터 운영 방안(모델)



그림 22

SW 공급망 관리센터 체계도

Demo

Secure Coding Education



Building Robust and Resilient Software

Demo

- 1 SQL Injection
- 2 System Prompt Injection
- 3 Azure API Management + WAF

End of Document